

AI i svenska myndigheter

Regler, gränser och praktiska vägval
för IT- och verksamhetsarkitekter

ERLAND LINDMARK



AI i svenska myndigheter

Regler, gränser och praktiska vägval för IT- och verksamhetsarkitekter

ERLAND LINDMARK

Innehåll

Inledning	4
Kapitel 1. Kartan över styrningen.....	8
Kapitel 2. AI-förordningen – vilken sorts användning har vi framför oss?.....	15
Kapitel 3. Informationen – vad matar vi AI:n med?	22
Kapitel 4. När AI påverkar människor och myndighetsbeslut.....	31
Kapitel 5. När någon annan tillhandahåller AI:n.....	39
Kapitel 6. Offentlighet, dokumentation och spårbarhet	50
Kapitel 7. Från idé till arkitekturbeslut	62
Kapitel 8. Praktiska scenarier.....	79
Bilaga A. Regelverkskarta och källor.....	89
Bilaga B. Exempel på sektorsspecifik reglering.....	94

Inledning

AI kan ge svenska myndigheter bättre beslutsunderlag, kortare handläggningstider, effektivare administration och bättre service. Samtidigt arbetar myndigheter i en miljö där användningen av information, automatisering och beslutsstöd redan är starkt reglerad.

Det är lätt att dra fel slutsats av detta. Den ena ytterligheten är att se AI som en vanlig teknisk komponent och anta att samma arbetssätt kan användas överallt. Den andra är att betrakta AI som så juridiskt riskfyllt att det är säkrast att avstå.

Båda leder fel.

Sveriges AI-strategi från 2026 har tvärtom en tydlig ambition att öka användningen av AI i offentlig förvaltning, samtidigt som rättssäkerhet, integritet, säker informationshantering och förtroende ska upprätthållas. Det är en bra utgångspunkt för den här boken: **AI ska användas där det skapar värde och där reglerna medger det - men med tillräcklig förståelse för när en djupare bedömning behövs.**

Bokens fråga är inte bara "får vi använda AI?"

För en IT- eller verksamhetsarkitekt är frågan sällan om AI i allmänhet är tillåtet. Mer användbart är att fråga:

- Vad ska AI-systemet faktiskt göra?
- Vilka människor kan påverkas?
- Vilken information ska behandlas?
- För vilket ändamål får informationen användas?
- Var och av vem sker behandlingen?
- Ska AI:n ge stöd, prioritera, rekommendera eller fatta beslut?
- Finns det sektorsspecifika regler för just den verksamheten?

En myndighet kan exempelvis få använda AI som teknik, men ändå sakna rätt att använda vissa personuppgifter för det aktuella ändamålet. Sekretess kan hindra att information lämnas till en extern tjänst. Ett användningsfall kan omfattas av särskilda krav i AI-förordningen. Och ett tekniskt möjligt beslutsstöd kan vara olämpligt om det inte går att upprätthålla saklighet, mänsklig kontroll eller tillräcklig spårbarhet.

Det betyder inte att svaret automatiskt är nej. Det betyder att **arkitekturen måste göra rätt frågor synliga tidigt.**

Tre lägen: grönt, gult och rött

Boken använder en enkel modell för den första bedömningen.

Grönt - normalt möjligt

Det finns inga tydliga indikatorer på särskilda rättsliga eller säkerhetsmässiga hinder. AI-användningen kan normalt hanteras inom myndighetens ordinarie styrning, informationssäkerhet och kvalitetssäkring.

Ett exempel kan vara ett godkänt internt AI-verktyg som hjälper en medarbetare att förbättra språk och struktur i en text som inte innehåller skyddsvärd information och där människan ansvarar för slutresultatet.

Gult - bedöm innan ni går vidare

En eller flera omständigheter gör att ytterligare analys behövs. Det kan handla om personuppgifter, sekretess, extern molntjänst, profilering, verksamhetskritisk information, beslut som påverkar enskilda eller sektorsspecifika registerregler.

Gult betyder inte förbjudet. Det betyder att arkitekten bör identifiera frågorna och se till att rätt kompetens kopplas in innan lösningen låses.

Rött - gå inte vidare innan frågan är klarlagd

Användningen kan träffa ett uttryckligt förbud, en särskilt reglerad högriskanvändning, säkerhetsskydd eller annan begränsning som gör att lösningen inte bör designas vidare som om den vore godkänd.

AI-förordningen innehåller exempel på AI-praktiker som är förbjudna och särskilda krav för högrisk-AI. Den innebär samtidigt inte att all AI är högrisk. Regleringen är riskbaserad, vilket är en viktig motvikt mot föreställningen att varje AI-användning kräver samma omfattande kontroll.

Arkitektens roll

Den här boken gör inte arkitekten till jurist. Målet är i stället att arkitekten ska kunna göra en **kvalificerad första bedömning**.

Det innebär att kunna:

1. känna igen vilka regelområden som sannolikt är relevanta,
2. formulera rätt frågor innan arkitekturen låses,
3. skilja mellan en hanterbar risk och ett faktiskt rättsligt hinder,
4. veta när jurist, dataskyddsombud, informationssäkerhet, säkerhetsskydd, arkivfunktion eller annan specialist behöver involveras,
5. dokumentera de arkitekturella antaganden som den fortsatta bedömningen bygger på.

Det är särskilt viktigt eftersom AI-lösningar ofta korsar flera traditionella ansvarsområden samtidigt. Samma lösning kan beröra dataskydd, sekretess, upphandling, informationssäkerhet, offentlighet och AI-förordningen.

Boken beskriver en generell grund - inte varje myndighets hela regelverk

Svenska myndigheter har olika uppdrag och olika speciallagstiftning. Tullverket, Polismyndigheten och Skatteverket är exempel på myndigheter där särskilda regler om personuppgiftsbehandling kan påverka hur AI-baserad analys, urval och brottsbekämpande behandling får utformas.

Därför återkommer en princip genom hela boken:

Kontrollera alltid om verksamheten omfattas av sektors- eller myndighetsspecifika regler utöver de generella regelverken.

Bilaga B ger tre korta exempel på detta. Exempelen är avsiktligt inte uttömmande.

Ett område i rörelse

AI-regleringen utvecklas snabbt. AI-förordningen tillämpas stegvis, nya EU-vägledningar publiceras och svenska regler och policyer förändras. Den 4 september 2026 beslutade regeringen exempelvis om en särskild utredning av hur offentlighetsprincipen ska tillämpas när myndigheter använder AI och externa molntjänster. Uppdraget ska redovisas senast den 15 november 2027.

Det illustrerar en viktig skillnad som boken kommer att hålla fast vid:

- **gällande rätt** beskriver vad som gäller nu,
- **officiell vägledning** hjälper till med tillämpningen,
- **strategier och policyer** anger inriktning men är inte samma sak som lag,
- **pågående utredningar** visar att en fråga kan vara under utveckling utan att ännu ha förändrat gällande rätt.

Källbilden i boken är därför daterad och ska verifieras på nytt inför publicering.

Så använder du boken

Du behöver inte läsa varje rättskälla från början till slut. Börja med kartan i nästa kapitel. Fortsätt sedan till det område som ditt användningsfall aktiverar: AI-förordningen, informationen, påverkan på människor och beslut, extern AI eller dokumentation och offentlighet.

Mot slutet samlar vi resonemangen i en praktisk kontrollmodell och ett antal scenarier.

Målet är att du efter boken ska kunna möta en ny AI-idé med en bättre fråga än både "varför inte?" och "det där får vi nog inte".

Den bättre frågan är:

Vad behöver vara sant för att vi ska kunna göra detta på ett tillåtet, säkert och ansvarsfullt sätt?

Viktigaste källorna

- Europaparlamentets och rådets förordning (EU) 2024/1689, AI-förordningen: <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>
- EU-kommissionens AI Act Service Desk: <https://ai-act-service-desk.ec.europa.eu/>
- Digg och IMY, *Riktlinjer för generativ AI inom offentlig förvaltning*: <https://www.digg.se/ai-for-offentlig-forvaltning/riktlinjer-for-generativ-ai>
- Regeringen, *Sveriges AI-strategi* (2026): <https://www.regeringen.se/regeringens-politik/sveriges-ai-strategi/>
- Regeringen, Dir. 2026:116, *En analys av tillämpningen av offentlighetsprincipen vid myndigheters användning av artificiell intelligens*: <https://www.regeringen.se/rattsliga-dokument/kommittedirektiv/2026/09/dir.-2026116>

Kapitel 1

Kartan över styrningen

När en myndighet använder AI styrs den sällan av ett enda regelverk. AI-förordningen är den mest uppenbara AI-specifika regleringen, men den ersätter inte de regler som redan gäller för offentlig verksamhet, personuppgifter, sekretess, upphandling eller säkerhet.

Arkitektens första uppgift är därför inte att memorera paragrafer, utan att förstå **vilka lager av styrning som kan bli relevanta för ett användningsfall**.

Sex lager av styrning

En praktisk karta kan beskrivas i sex lager:

1. **Grundläggande krav på offentlig verksamhet** – regeringsformen och förvaltningslagen.
2. **AI-specifik reglering** – framför allt EU:s AI-förordning.
3. **Regler om information** – GDPR, dataskyddslagen, offentlighets- och sekretesslagen, arkivreglering och säkerhetsskydd.
4. **Regler om hur lösningen anskaffas och används** – exempelvis LOU och avtalsmässiga krav.
5. **Sektorsspecifik reglering** – särskilda register- och verksamhetsförfattningar för den aktuella myndigheten.
6. **Icke-bindande styrning** – strategier, vägledningar, policyer och interna regler.

Ett användningsfall kan beröra flera lager samtidigt. En generativ AI-tjänst för att sammanfatta ärenden kan exempelvis beröra AI-förordningen, GDPR, sekretess, myndighetens interna informationsklassning och reglerna för den externa leverantören.

Grundlag och förvaltningsrätt ligger under AI-lagret

Förvaltningslagen uttrycker tre principer som är särskilt användbara för AI-arkitektur: **legalitet, objektivitet och proportionalitet**. En myndighet får bara vidta åtgärder som har stöd i rättsordningen, ska vara saklig och opartisk och får inte ingripa mer långtgående än vad som behövs.

Regeringsformen innehåller dessutom objektivitetsprincipen: myndigheter ska beakta allas likhet inför lagen samt iaktta saklighet och opartiskhet.

Detta är viktigt för AI eftersom tekniken inte förändrar myndighetens grundläggande ansvar. Ett AI-system kan hjälpa till att analysera, prioritera eller rekommendera, men myndigheten måste fortfarande kunna säkerställa att de grunder som används är tillåtna, relevanta och sakliga.

Arkitekturfråga: Om AI:n påverkar hur människor prioriteras, bedöms eller behandlas – kan vi förklara vilka faktorer som får påverka resultatet och varför?

AI-förordningen lägger till AI-specifika krav

EU:s AI-förordning, förordning (EU) 2024/1689, bygger på risk. Den innehåller bland annat:

- krav på AI-kompetens för leverantörer och användande organisationer,
- förbjudna AI-praktiker,
- regler för högrisk-AI,
- krav på mänsklig kontroll, dokumentation, loggning, robusthet och säkerhet i relevanta fall,
- transparenskrav för vissa AI-system och AI-genererat innehåll,
- särskilda regler för generella AI-modeller.

För myndigheten är den första praktiska uppgiften därför att förstå **vilken roll organisationen har och vilken kategori det aktuella användningsfallet hamnar i**.

Det är samtidigt viktigt att inte göra AI-förordningen större än den är. Den är inte en ersättning för GDPR, förvaltningsrätt eller sekretessregler. En deployer av ett högrisk-AI-system måste till exempel följa AI-förordningens skyldigheter utan att detta ersätter andra skyldigheter enligt unionsrätt eller nationell rätt.

Arkitekturfråga: Är detta ett vanligt lågrisk-användningsfall, ett transparensfall, ett högrisk-användningsfall eller något som kan träffa ett förbud?

Personuppgifter: GDPR och svensk kompletterande lag

Om AI-systemet behandlar personuppgifter blir GDPR relevant oavsett om systemet är generativt, prediktivt eller regelbaserat på något annat sätt.

GDPR:s grundprinciper omfattar bland annat laglighet, korrekthet och transparens samt att personuppgifter ska samlas in för särskilda, uttryckligt angivna och berättigade ändamål. För AI-arkitektur gör det ändamålet centralt.

Frågan blir alltså inte bara om uppgifterna redan finns hos myndigheten. Man behöver också förstå om de får användas **för den nya AI-behandlingen**.

Den svenska dataskyddslagen kompletterar GDPR och sektorsspecifika registerförfattningar kan i sin tur precisera eller begränsa behandlingen ytterligare.

Arkitekturfråga: Vilka personuppgifter behandlas, för vilket ändamål och med vilket rättsligt stöd?

Offentlighet och sekretess är två olika frågor

I myndighetsmiljö måste arkitekten ofta hantera två frågor samtidigt:

1. Kan informationen bli en allmän handling?
2. Får informationen lämnas ut eller göras tillgänglig för den aktör som behandlar den?

Tryckfrihetsförordningen innehåller reglerna om allmänna handlingars offentlighet. Offentlighets- och sekretesslagen begränsar i vissa fall rätten att röja uppgifter.

Detta blir konkret när en myndighet använder en extern AI-tjänst. OSL innehåller en bestämmelse som under vissa förutsättningar gör det möjligt att lämna sekretessbelagda uppgifter till en aktör som endast tekniskt bearbetar eller lagrar dem för myndighetens räkning, men bestämmelsen är villkorad och innebär inte att varje AI-tjänst automatiskt är lämplig eller tillåten.

Att en AI-leverantör tränar egna modeller på informationen, använder den för andra ändamål eller på annat sätt gör mer än ren teknisk bearbetning kan därför vara en avgörande arkitekturfråga.

Dessutom är rättsläget kring AI och allmänna handlingar under fortsatt analys. Regeringen tillsatte den 4 september 2026 en utredning som särskilt ska analysera när upptagningar som genereras eller lagras genom AI-verktyg och externa molntjänster utgör allmänna handlingar. Det förändrar inte gällande rätt idag, men visar att området behöver följas.

Arkitekturfråga: Vad skickas till tjänsten, vad sparas där, vad kommer tillbaka och vilka aktörer kan få faktisk tillgång till informationen?

Säkerhetsskydd: när konsekvensen är större än vanlig informationssäkerhet

Säkerhetsskyddslagen gäller verksamhet som är av betydelse för Sveriges säkerhet eller omfattas av ett bindande internationellt säkerhetsskyddsåtagande. Den kräver bland annat säkerhetsskyddsanalys och skyddsåtgärder för information och informationssystem som berör säkerhetskänslig verksamhet.

Detta är ett tydligt exempel på en situation där en vanlig riskbedömning för en moln- eller AI-tjänst inte räcker. Om en annan aktör genom en upphandling, ett avtal eller ett samarbete kan få tillgång till säkerhetskänslig verksamhet kan särskilda krav på säkerhetsskyddsavtal och andra åtgärder aktualiseras.

Arkitekturfråga: Kan AI-lösningen eller dess leverantör få tillgång till information, system eller beroenden som ingår i säkerhetskänslig verksamhet?

Arkiv och spårbarhet

När AI används i handläggning eller andra myndighetsprocesser uppstår information som kan behöva bevaras, kunna återsökas eller omfattas av gallringsbeslut. Arkivlagen ger den generella ramen för myndigheternas arkiv, medan mer detaljerade regler kan följa av föreskrifter och myndighetens informationshantering.

Arkitekten behöver därför tänka på vilka artefakter som systemet skapar:

- promptar,
- indata,
- AI-genererade svar,
- loggar,
- modell- eller versionsinformation,

- bedömningar som görs av människor med stöd av AI.

Det betyder inte att allt alltid ska sparas. Men bevarande och gallring bör vara ett designbeslut, inte en bieffekt av vad leverantörens standardinställning råkar göra.

Arkitekturfråga: Vilken information behöver kunna rekonstrueras för att förstå vad som hände i efterhand?

Anskaffning och leverantörsstyrning

När AI köps eller avropas kommer upphandlingsregler och avtal in i bilden. För arkitekten är den viktigaste poängen inte själva upphandlingsförfarandet utan att **rättsliga och säkerhetsmässiga krav måste bli tekniskt och avtalsmässigt verifierbara krav.**

Exempel:

- var data får behandlas,
- om leverantören får använda data för träning,
- vilka underleverantörer som får anlitas,
- vilka loggar som finns,
- hur data raderas,
- hur myndigheten kan byta leverantör,
- vilka säkerhetskrav som gäller,
- hur incidenter rapporteras,
- vilken dokumentation myndigheten får tillgång till.

Digg och IMY:s gemensamma riktlinjer för generativ AI inom offentlig förvaltning behandlar därför inte bara dataskydd utan också anskaffning, sekretess, informationssäkerhet, upphovsrätt, arbetsrätt, etik och ledningsansvar.

Arkitekturfråga: Kan vi formulera och följa upp de rättsliga förutsättningarna som konkreta krav på lösningen och leverantören?

Några tvärgående regler får inte tappas bort

Tre regelområden behöver inte dominera boken, men kan bli avgörande i vissa AI-lösningar.

Upphovsrätt blir relevant när myndigheten använder skyddat material som underlag, bygger större kunskapsbaser, tränar eller finjusterar modeller eller publicerar AI-genererat material som bygger på andras verk. Den svenska upphovsrättslagen innehåller bland annat regler om text- och datautvinning. AI-förordningen innehåller dessutom upphovsrättsrelaterade skyldigheter för leverantörer av generella AI-modeller.

Digital tillgänglighet blir relevant när AI byggs in i webbplatser eller andra digitala tjänster för allmänheten. Lagen (2018:1937) om tillgänglighet till digital offentlig service gäller digital service som tillhandahålls av offentliga aktörer och ställer tillgänglighetskrav på de tekniska lösningar som omfattas. En AI-chatbot på myndighetens webbplats måste därför bedömas som en del av den digitala tjänsten, inte bara som en AI-komponent.

Cybersäkerhetslagen (2025:1506) genomför delar av NIS 2-direktivet och gäller verksamhetsutövare som omfattas av lagens tillämpningsområde. För sådana myndigheter och verksamheter kan AI-tjänster, integrationspunkter och leverantörsberoenden behöva ingå i den övergripande cybersäkerhetsstyrningen och riskhanteringen.

Dessa områden är typiska **gula kontrollfrågor**: de gör inte AI-användningen otillåten i sig, men kan skapa krav som måste byggas in i lösningen.

Sektorsspecifik reglering kan ändra svaret

De generella regelverken är bara basen. Många myndigheter har specialregler om vilka uppgifter som får behandlas, för vilka ändamål, hur sökning och analys får ske och hur länge information får bevaras.

Det är särskilt tydligt inom exempelvis:

- brottsbekämpning,
- beskattning,
- tullverksamhet,
- folkbokföring,
- hälso- och sjukvård,
- socialtjänst.

En arkitekt bör därför aldrig avsluta regelanalysen med konstaterandet "GDPR är hanterat".

Arkitekturfråga: Finns det registerförfattning, verksamhetslag eller annan specialreglering för den process och de uppgifter som AI:n ska använda?

Bilaga B visar kort hur detta kan se ut för Tullverket, Polismyndigheten och Skatteverket.

Strategi, vägledning och intern policy är inte samma sak som lag

Bokens sista lager är också viktigt, men har en annan rättslig karaktär.

Sveriges AI-strategi från 2026 uttrycker en tydlig ambition att offentlig förvaltning ska använda AI för högre effektivitet, kvalitet och service samtidigt som förtroende, rättssäkerhet, integritet och säkerhet värnas. Digg och IMY har samtidigt tagit fram praktiska riktlinjer för generativ AI i offentlig förvaltning.

Dessa källor är viktiga för hur myndigheter bör arbeta, men de ska inte beskrivas som om varje rekommendation vore ett uttryckligt lagkrav.

Samma sak gäller myndighetens interna AI-policy. Den kan vara bindande internt och mer restriktiv än vad lagen kräver, men den är fortfarande ett annat slags styrning än lag och förordning.

För arkitekten är skillnaden central:

Typ av styrning	Exempel	Hur den ska läsas
Bindande rätt	AI-förordningen, GDPR, OSL	Sätter rättsliga krav och gränser
Sektorsregler	Register- och verksamhetsförfattningar	Preciserar vad som gäller i en viss verksamhet
Officiell vägledning	Digg/IMY, EU-kommissionen	Hjälper till att tolka och tillämpa regler
Strategi/policy	Sveriges AI-strategi, molnpolicy	Anger inriktning och prioriteringar
Intern styrning	AI-policy, informationsklassning, arkitekturprinciper	Styr den egna organisationens genomförande

En enkel första regelkarta

När ett nytt AI-användningsfall kommer upp kan arkitekten börja med följande kontroll:

Fråga	Om svaret är ja - titta först på
Använder vi ett AI-system som omfattas av AI-förordningen?	AI-förordningen
Behandlas personuppgifter?	GDPR, dataskyddslagen och eventuell specialreglering
Berörs myndighetsutövning eller beslut om enskild?	Regeringsformen, förvaltningslagen, AI-förordningen och relevant specialreglering
Finns sekretessbelagda uppgifter?	OSL och informationssäkerhet
Är verksamheten säkerhetskänslig?	Säkerhetsskyddslagen och säkerhetsskyddsförordningen
Använder vi extern leverantör eller molntjänst?	OSL, dataskydd, säkerhet, LOU och avtal
Skapar AI:n handlingar, loggar eller beslutsunderlag?	TF, OSL, arkivregler och verksamhetens dokumentationskrav
Finns särskild lagstiftning för verksamhetsområdet?	Relevant register- och verksamhetsförfattning

Detta är inte den fullständiga juridiska analysen. Det är **arkitektens karta över vart den fortsatta analysen behöver gå**.

Sammanfattning

AI i en svensk myndighet styrs av flera lager samtidigt. AI-förordningen är central men aldrig ensam. Förvaltningsrätt, dataskydd, offentlighet och sekretess, säkerhetsskydd, arkiv, upphandling och sektorsspecifika regler kan vara lika avgörande för hur lösningen får utformas.

Den viktigaste vanan för en arkitekt är därför att flytta fokus från frågan:

"Vilka AI-regler finns?"

till:

”Vilka delar av vår användning aktiverar vilka regelverk?”

I nästa kapitel går vi djupare i AI-förordningen och den riskbaserade klassificering som avgör när särskilda AI-specifika krav träder in.

Viktigaste källorna

- Regeringsformen (1974:152), särskilt 1 kap. 9 §: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/kungorelse-1974152-om-beslutad-ny-regeringsform_sfs-1974-152/
- Förvaltningslag (2017:900), särskilt 5 §: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/forvaltningslag-2017900_sfs-2017-900/
- Förordning (EU) 2024/1689, AI-förordningen: <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>
- EU-kommissionens AI Act Service Desk: <https://ai-act-service-desk.ec.europa.eu/>
- Förordning (EU) 2016/679, GDPR, särskilt artikel 5: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- Lag (2018:218) med kompletterande bestämmelser till EU:s dataskyddsförordning: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-2018218-med-kompletterande-bestammelser_sfs-2018-218/
- Tryckfrihetsförordning (1949:105), särskilt 2 kap.: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/tryckfrihetsforordning-1949105_sfs-1949-105/
- Offentlighets- och sekretesslag (2009:400): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/offentlighets-och-sekretesslag-2009400_sfs-2009-400/
- Säkerhetsskyddslag (2018:585): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/sakerhetsskyddslag-2018585_sfs-2018-585/
- Arkivlag (1990:782): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/arkivlag-1990782_sfs-1990-782/
- Myndighetsförordning (2007:515): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/myndighetsforordning-2007515_sfs-2007-515/
- Lag (2016:1145) om offentlig upphandling: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-20161145-om-offentlig-upphandling_sfs-2016-1145/
- Digg och IMY, *Riktlinjer för generativ AI inom offentlig förvaltning*: <https://www.digg.se/ai-for-offentlig-forvaltning/riktlinjer-for-generativ-ai>
- Regeringen, *Sveriges AI-strategi* (2026): <https://www.regeringen.se/regeringens-politik/sveriges-ai-strategi/>
- Regeringen, Dir. 2026:116: <https://www.regeringen.se/rattsliga-dokument/kommittedirektiv/2026/09/dir.-2026116>

Kapitel 2

AI-förordningen - vilken sorts användning har vi framför oss?

AI-förordningen är den mest uppenbara AI-specifika regleringen. För arkitekten fungerar den framför allt som en **klassificeringsmodell**, inte som ett enda ja- eller nej-svar på om AI får användas.

Det praktiska arbetet börjar därför med tre frågor:

1. Har vi ett AI-system som omfattas av förordningen?
2. Vilken roll har myndigheten i förhållande till systemet?
3. Vilken risk- eller transparenskategori hamnar det aktuella användningsfallet i?

Först därefter går det att förstå vilka AI-specifika krav som blir relevanta.

Användningsfallet avgör

AI-förordningen definierar ett AI-system som ett maskinbaserat system som är utformat för att fungera med varierande grad av autonomi, som kan vara adaptivt efter driftsättning och som utifrån indata härleder hur det ska generera utdata som exempelvis prediktioner, innehåll, rekommendationer eller beslut som kan påverka fysiska eller virtuella miljöer.

Det betyder att arkitekten inte bör börja med frågan om organisationen använder exempelvis en "AI-produkt" eller en viss leverantör. Det avgörande är **vad systemet faktiskt gör i den aktuella lösningen**.

En språkmodell som används för att förbättra formuleringar i en redan offentlig text är ett annat användningsfall än samma modell när den används för att rangordna sökande, analysera misstänkta beteenden eller ge underlag till beslut om enskilda.

Arkitekturfråga: Vad är AI-systemets funktion i just denna process, vilka utdata producerar det och vad kan dessa utdata påverka?

Myndigheten är ofta deployer - men inte alltid bara det

AI-förordningen skiljer mellan olika roller. Två är särskilt viktiga för en myndighet:

- **provider** – den som utvecklar eller låter utveckla ett AI-system och tillhandahåller eller tar det i bruk under eget namn eller varumärke,
- **deployer** – den organisation som använder ett AI-system under sin egen kontroll.

En myndighet som köper en färdig AI-tjänst är alltså ofta deployer. Men om myndigheten utvecklar ett eget system, låter bygga ett system som sedan tas i bruk under myndighetens namn eller gör vissa större förändringar kan providerrollen också bli relevant.

Det är därför farligt att tänka att "leverantören ansvarar för AI Act". Leverantören kan ha omfattande skyldigheter, men myndigheten kan samtidigt ha egna skyldigheter som deployer.

Arkitekturfråga: Är vi bara användare av en färdig tjänst, eller har vi utvecklat, förändrat, paketerat eller tagit systemet i bruk på ett sätt som förändrar vår roll?

Fyra praktiska riskzoner

För arkitekten är det användbart att förenkla AI-förordningen till fyra praktiska zoner.

1. Förbjuden användning

Vissa AI-praktiker är förbjudna. Förbuden omfattar bland annat vissa manipulerande eller exploaterande tekniker, social scoring, vissa former av individuell brottsriskbedömning, ospecificerad insamling av ansiktsbilder för ansiktsgenkänningsdatabaser, viss känsligenkänning och vissa former av biometrisk kategorisering.

Här är bokens färgkod **rött**. Om användningsfallet verkar träffa ett förbud ska arkitekten inte försöka "designa runt" problemet utan se till att rättslig specialistbedömning görs innan arbetet går vidare.

Det finns undantag och detaljvillkor för vissa förbud. Därför ska en kort beskrivning i en arkitekturbok aldrig användas som slutlig juridisk klassificering.

Arkitekturfråga: Finns någon del av användningen som bedömer, påverkar eller kategoriserar människor på ett sätt som ligger nära de uttryckligen förbjudna praktikerna?

2. Högrisk-AI

AI-system kan klassificeras som högrisk genom två huvudvägar:

- AI som säkerhetskomponent eller del av vissa reglerade produkter,
- AI i särskilt känsliga användningsområden enligt bilaga III.

Bilaga III omfattar bland annat vissa användningar inom biometrik, kritisk infrastruktur, utbildning, arbetsliv, tillgång till väsentliga offentliga och privata tjänster, brottsbekämpning, migration och gränskontroll samt rättskipning och demokratiska processer.

För offentlig sektor är detta en central kontrollpunkt. Ett AI-system blir inte högrisk bara för att det används av en myndighet. Det är **det avsedda användningsfallet och dess funktion** som är avgörande.

När högriskreglerna är tillämpliga ställs bland annat krav på riskhantering, data och datastyrning, dokumentation, loggning, information till deployer, mänsklig kontroll, robusthet, cybersäkerhet och noggrannhet.

För deployers tillkommer egna krav, exempelvis att använda systemet enligt instruktionerna, utse personer med tillräcklig kompetens och befogenhet för mänsklig kontroll, övervaka systemets drift och i relevanta fall behålla automatiskt genererade loggar.

För vissa offentliga deployers av högrisk-AI krävs dessutom en bedömning av påverkan på grundläggande rättigheter innan systemet tas i bruk. Den bedömningen kompletterar, snarare än ersätter, en eventuell konsekvensbedömning enligt dataskyddsreglerna.

Arkitekturfråga: Berör AI-systemet ett område i bilaga III eller en reglerad produkt, och påverkar det människor på det sätt som gör klassificeringen till högrisk relevant?

Tillämpningsdatumerna är en del av arkitekturen

AI-förordningen trädde i kraft den 1 augusti 2024, men olika delar började tillämpas vid olika tidpunkter. Efter 2026 års Digital Omnibus ser tidslinjen i stora drag ut så här:

Regelområde	Tillämpning
AI-kompetens och huvuddelen av förbuden	2 februari 2025
Styrningsregler och regler för general-purpose AI-modeller	2 augusti 2025
Huvuddelen av AI-förordningen, inklusive transparensregler	2 augusti 2026
Vissa nya förbjudna praktiker efter 2026 års ändring	2 december 2026
Högriskfall enligt artikel 6.2 och bilaga III	2 december 2027
Produktanknutna högriskfall enligt artikel 6.1 och bilaga I	2 augusti 2028

Det innebär att ett krav som ännu inte är fullt tillämpligt ändå kan vara viktigt i en arkitektur som ska leva i flera år. En lösning som införs 2026 och förväntas användas 2028 bör därför inte designas som om 2027–2028 års krav inte finns.

Arkitekturfråga: Vilka regler gäller när lösningen tas i bruk – och vilka kommer att gälla under dess planerade livslängd?

3. Transparens: ibland måste människor få veta att AI används

AI-förordningen innehåller transparensregler som gäller vissa användningar även när systemet inte är högrisk.

Exempel är att människor i vissa fall ska informeras när de interagerar direkt med ett AI-system. Det finns också särskilda regler för bland annat syntetiskt eller manipulerat innehåll, deepfakes och vissa AI-genererade texter som publiceras för att informera allmänheten om frågor av allmänt intresse.

För en myndighet kan detta bli relevant för exempelvis:

- chatbotar och digitala assistenter,
- automatiskt genererade texter på webbplatser,
- genererat ljud, bild eller video,
- tjänster där den enskilde annars rimligen kan tro att kontakten sker med en människa.

Transparens behöver därför finnas med i arkitekturen som funktion, inte läggas på sist som en informationsruta.

Arkitekturfråga: Behöver användaren eller den berörda personen informeras om att AI används, och var i tjänsten måste denna information i så fall lämnas?

4. Minimal eller begränsad AI-risk betyder inte “inga regler”

Många AI-användningar faller inte in under förbud eller högriskregler. Det är viktigt, eftersom boken inte ska skapa intrycket att all AI i en myndighet är högrisk.

Exempel på relativt okomplicerade användningar kan vara:

- språkstöd för offentlig eller okänslig text,
- idé- och struktureringsstöd,
- sammanfattning av material som får behandlas i den valda tjänsten,
- tekniskt stöd där resultatet alltid granskas och inte påverkar enskildas rättigheter eller skyldigheter.

Men **minimal risk enligt AI-förordningen betyder bara att de mer omfattande AI Act-kraven inte aktiveras**. GDPR, sekretess, säkerhetsskydd, offentlighet, upphovsrätt, arkivregler och sektorsspecifik lagstiftning kan fortfarande vara avgörande.

Detta är ett av bokens viktigaste budskap:

Låg risk enligt AI-förordningen är inte samma sak som rättsligt oreglerad användning.

AI-kompetens är redan ett krav

Artikel 4 kräver efter 2026 års Digital Omnibus att providers och deployers vidtar åtgärder för att **stödja utvecklingen av AI-kompetens** hos personal och andra som hanterar eller använder AI-system för deras räkning. Vid utformningen ska bland annat teknisk kunskap, erfarenhet, utbildning och användningskontext beaktas. Den tidigare formuleringen om att säkerställa en viss “tillräcklig nivå” har tagits bort; skyldigheten att vidta kompetensåtgärder finns däremot kvar.

För en myndighet betyder det att AI-kompetens inte bör reduceras till en allmän introduktionskurs för alla. Åtgärderna behöver vara **roll- och användningsfallsanpassade**.

En arkitekt som utformar AI-baserat beslutsstöd behöver annan kompetens än en medarbetare som använder generativ AI för språklig bearbetning.

Arkitekturfråga: Vilken kompetens krävs för dem som designar, förvaltar, övervakar och använder just detta AI-system?

Mänsklig kontroll måste vara verklig

Mänsklig kontroll återkommer på flera ställen i AI-förordningen och är särskilt viktig för högrisk-AI. När de relevanta högriskreglerna är tillämpliga ska deployers se till att personer som får ansvar för mänsklig kontroll har nödvändig kompetens, utbildning och befogenhet samt det stöd som behövs.

Det betyder att en "human in the loop" inte automatiskt löser problemet.

Om människan:

- inte förstår systemets begränsningar,
- saknar tid att göra en självständig bedömning,
- saknar åtkomst till underlaget,
- inte kan avvika från AI:ns rekommendation,
- eller i praktiken alltid accepterar resultatet,

är den mänskliga kontrollen svag även om processen formellt innehåller ett manuellt steg.

För arkitekten är detta en designfråga om gränssnitt, behörigheter, information, loggning och process – inte bara en organisationsfråga.

Arkitekturfråga: Kan den människa som ska utöva kontroll faktiskt förstå, ifrågasätta och ändra AI-systemets resultat?

General-purpose AI: skilj på modellen och myndighetens användning

Generativa tjänster bygger ofta på så kallade general-purpose AI-modeller, GPAI. AI-förordningen innehåller särskilda skyldigheter för providers av sådana modeller, bland annat kring dokumentation, transparens och upphovsrätt. Modeller med systemrisk får ytterligare krav.

En svensk myndighet som använder en kommersiell språkmodell är normalt inte provider av grundmodellen. Men leverantörens skyldigheter är ändå relevanta för myndighetens kravställning.

Arkitekten behöver exempelvis förstå vilken dokumentation som finns, hur modellen används i den färdiga tjänsten, vilka begränsningar leverantören anger och hur uppdateringar av modellen kan påverka lösningens beteende.

Samtidigt måste myndighetens **eget användningsfall** klassificeras separat. Att grundmodellen är en GPAI-modell säger inte i sig om myndighetens lösning är högrisk.

Arkitekturfråga: Vad behöver vi veta om grundmodellen för att kunna bedöma och styra vår egen lösning?

En praktisk AI-förordningskontroll för arkitekten

När ett nytt AI-användningsfall kommer upp kan följande kontroll användas som första steg:

Kontrollfråga	Varför den är viktig
Är detta ett AI-system enligt förordningen?	Avgör om AI-förordningen över huvud taget är tillämplig
Vilken roll har myndigheten?	Provider och deployer har olika skyldigheter
Vad är systemets avsedda användning?	Riskklassningen bygger på användningsfallet
Ligger användningen nära någon förbjuden praktik?	Kräver omedelbar fördjupad bedömning
Kan användningen omfattas av högriskreglerna?	Aktiverar omfattande krav för system och deployer
Finns transparenskrav?	Kan kräva information eller märkning i tjänsten
Vilken mänsklig kontroll krävs?	Påverkar process, gränssnitt, roller och behörigheter
Vilken AI-kompetens behöver organisationen?	Ett uttryckligt krav som måste omsättas praktiskt
Vilka tillämpningsdatum gäller under systemets livstid?	Krav kan börja gälla efter införandet
Vilken annan lagstiftning gäller parallellt?	AI-förordningen ersätter inte övrig rätt

Bedömning: grönt, gult eller rött

Den förenklade färgmodellen kan nu preciseras:

Grönt

AI-systemet verkar ligga utanför förbjudna och högriskklassade användningar. Eventuella transparenskrav och övriga regelverk är hanterbara inom vanlig styrning.

Gult

Användningen påverkar människor, ligger nära bilaga III, omfattar känsliga funktioner eller gör organisationens roll oklar. Klassificeringen och kraven behöver utredas innan arkitekturen låses.

Rött

Användningen kan träffa en förbjuden praktik eller någon annan tydlig rättslig begränsning. Lösningen bör inte gå vidare innan rättsläget är klarlagt.

Färgmodellen är ett triageverktyg. Den är inte en juridisk klassificering.

Sammanfattning

AI-förordningen ska inte läsas som en lista över allt en myndighet får eller inte får göra med AI. För arkitekten är den framför allt ett sätt att **klassificera användningsfallet och förstå vilka AI-specifika skyldigheter som aktiveras**.

Den praktiska ordningen är:

1. avgör om lösningen omfattar ett AI-system,
2. identifiera organisationens roll,
3. beskriv det avsedda användningsfallet,
4. kontrollera förbud, högrisk och transparens,
5. identifiera krav på mänsklig kontroll, kompetens, dokumentation och övervakning,
6. kontrollera tillämpningsdatumen,
7. gå därefter vidare till övrig lagstiftning.

Nästa kapitel lämnar klassificeringen av själva AI-systemet och fokuserar på informationen: **vad får vi egentligen mata AI:n med?**

Viktigaste källorna

- Konsoliderad AI-förordning (EU) 2024/1689, lydelse efter ändring 2026-07-27: <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng>
- Förordning (EU) 2026/1744, Digital Omnibus on AI: <https://eur-lex.europa.eu/legal-content/SV/TXT/?uri=CELEX:32026R1744>
- EU-kommissionen, *AI Act – Regulatory framework*: <https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai>
- EU-kommissionen, *AI talent, skills and literacy* – artikel 4 efter Digital Omnibus: <https://digital-strategy.ec.europa.eu/en/policies/ai-talent-skills-and-literacy>
- AI Act Service Desk, artikel 3 – definitioner: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-3>
- AI Act Service Desk, artikel 4 – AI literacy: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-4>
- AI Act Service Desk, artikel 5 – förbjudna AI-praktiker: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-5>
- AI Act Service Desk, artikel 26 – deployers av högrisk-AI: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-26>
- AI Act Service Desk, artikel 27 – fundamental rights impact assessment: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-27>
- AI Act Service Desk, artikel 50 – transparens: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-50>

Kapitel 3

Informationen - vad matar vi AI:n med?

Diskussionen börjar lätt med modellval, kvalitet eller molndrift. För en myndighet kommer en viktigare fråga först:

Vilken information ska AI-lösningen få tillgång till, och för vilket ändamål?

När den frågan är besvarad går det att bedöma om användningen är okomplicerad, kräver skyddsåtgärder eller behöver en fördjupad analys.

Det här kapitlet handlar därför inte främst om AI-modellen. Det handlar om informationsflödet runt modellen: promptar, dokument, databaser, RAG-index, loggar, träningsdata, metadata och resultat.

Kartlägg informationen först

En arkitekt bör kunna beskriva informationsflödet innan en AI-tjänst väljs:

1. Vilka informationsmängder går in i lösningen?
2. Varifrån kommer de?
3. Varför behöver AI:n just dessa uppgifter?
4. Vem eller vad får tillgång till dem?
5. Var behandlas de?
6. Sparas de, loggas de eller används de för träning?
7. Vilken information kommer ut ur lösningen?
8. Hur används resultatet vidare?

Det gör det möjligt att skilja mellan flera rättsliga frågor som annars lätt blandas ihop.

En uppgift kan exempelvis vara en personuppgift utan att omfattas av sekretess. En sekretessbelagd uppgift behöver inte vara en personuppgift. Och information som inte omfattas av någon av dessa kategorier kan ändå vara så verksamhetskritisk att den behöver ett starkt skydd.

Personuppgifter: GDPR gäller även när AI:n bara är ett verktyg

När personuppgifter behandlas i samband med utveckling eller användning av AI gäller GDPR. IMY framhåller att verksamheten bland annat måste följa de grundläggande principerna, ha rättslig grund och informera de registrerade om behandlingen.

Det är alltså inte AI-användningen i sig som skapar rätten att behandla personuppgifter.

För arkitekten är särskilt fyra GDPR-principer praktiskt viktiga:

Ändamålsbegränsning

Personuppgifter får samlas in för särskilda, uttryckligt angivna och berättigade ändamål och får inte senare användas på ett sätt som är oförenligt med dessa ändamål.

Det gör formuleringen **"vi vill använda vår data för AI"** otillräcklig. Arkitekten behöver bygga på ett mer konkret ändamål, exempelvis:

- sammanfatta inkomna handlingar för en handläggare,
- hitta relevanta stycken i ett avgränsat dokumentbestånd,
- klassificera ärenden för manuell vidare behandling,
- identifiera tekniska avvikelser i systemloggar.

Ju bredare och mer otydligt ändamålet är, desto svårare blir det att motivera vilka personuppgifter AI:n behöver.

Uppgiftsminimering

AI-lösningen ska inte få tillgång till fler personuppgifter än vad som behövs för ändamålet.

Detta är en viktig arkitekturprincip. Ett RAG-system behöver exempelvis inte automatiskt indexera hela myndighetens dokumentlager bara för att det är tekniskt möjligt. Ett analysflöde kan ofta filtrera, pseudonymisera eller ta bort irrelevanta fält innan informationen når modellen.

Arkitekturfråga: Kan samma verksamhetsnytta uppnås med mindre information?

Riktighet

Personuppgifter ska vara riktiga och vid behov uppdaterade. AI kan samtidigt skapa felaktiga slutsatser, sammanblandningar eller påståenden.

Det innebär att output som innehåller personuppgifter inte bör betraktas som korrekt bara för att den är språkligt övertygande. Ju större betydelse resultatet får för en person, desto viktigare blir verifiering mot auktoritativa källor.

Lagringsminimering

Personuppgifter ska normalt inte sparas längre än vad som behövs för ändamålet. För AI-lösningar behöver man därför förstå vad som faktiskt lagras:

- promptar,
- bifogade dokument,
- chatt- eller sessionshistorik,
- embeddings och vektordatabaser,
- tekniska loggar,
- feedbackdata,
- modelloutput.

Samtidigt kan annan lagstiftning, exempelvis arkivregler, innebära att viss information behöver bevaras. Radering enligt GDPR och bevarande enligt arkivrätten måste därför hanteras tillsammans, inte som två isolerade tekniska krav.

Känsliga och särskilt skyddsvärda personuppgifter

Vissa personuppgifter kräver större försiktighet. GDPR innehåller särskilda regler för känsliga personuppgifter, och IMY pekar även ut andra integritetskänsliga uppgifter som kan kräva högre säkerhetsnivå.

Exempel är uppgifter om:

- hälsa,
- biometrisk identifiering,
- politiska eller religiösa förhållanden,
- fackligt medlemskap,
- sexualliv eller sexuell läggning,
- lagöverträdelser,
- skyddade personuppgifter,
- värderande personprofiler.

Att en AI-tjänst tekniskt kan bearbeta uppgifterna säger inget om myndigheten får använda dem på det sättet.

Gul signal: Lösningen behandlar stora mängder personuppgifter, känsliga uppgifter, profiler eller information om sårbara grupper.

Rättslig grund är inte samma sak som tekniskt behov

För myndigheter är rättslig grund ofta kopplad till rättslig förpliktelse eller uppgift av allmänt intresse/myndighetsutövning. Men den exakta bedömningen beror på verksamheten och den behandling som faktiskt sker.

Arkitektens uppgift är inte att själv slutligt avgöra rättslig grund. Däremot måste arkitekturbeskrivningen vara så konkret att jurist eller dataskyddsfunktion kan göra bedömningen.

Det innebär att man behöver kunna svara på:

- vilka uppgifter som behandlas,
- för vilka personer,
- i vilket steg av processen,
- vilket verksamhetsändamål behandlingen stödjer,
- vilka mottagare som får tillgång,
- hur länge uppgifterna behandlas.

En vag lösningsbeskrivning ger också en vag juridisk analys.

Konsekvensbedömning: ibland måste riskerna analyseras före införandet

Om en planerad personuppgiftsbehandling sannolikt medför hög risk för människors fri- och rättigheter krävs en konsekvensbedömning enligt GDPR, en DPIA. IMY beskriver den som en pågående och dokumenterad process för högriskbehandlingar, inte som en engångsblankett.

AI kan bidra till att en sådan bedömning behövs, särskilt vid exempelvis:

- omfattande profilering eller systematiska bedömningar av personer,
- stora mängder känsliga personuppgifter,
- systematisk övervakning,
- ny teknik i kombination med andra riskfaktorer,
- behandling som kan få betydande konsekvenser för enskilda.

Om hög risk kvarstår trots planerade skyddsåtgärder kan förhandssamråd med IMY krävas innan behandlingen påbörjas.

Arkitekturkonsekvens: identifiera behovet av DPIA innan designen och avtalen är låsta. Då kan resultatet fortfarande påverka informationsmängder, integrationer, loggning, säkerhetsåtgärder och leverantörsval.

Sekretess: får uppgiften lämnas till AI-tjänsten?

Sekretessfrågan är skild från GDPR.

När en myndighet använder en extern AI-tjänst kan leverantören eller en mellanhand få del av myndighetens uppgifter. Digg beskriver att det som utgångspunkt kan vara fråga om ett utlämnande till den externa parten. Därför måste myndigheten bedöma om uppgifter omfattas av sekretess eller annan tystnadsplikt och om det finns rättsligt stöd för att lämna dem vidare.

Det gäller även om:

- informationen bara finns i en prompt,
- dokumentet betraktas som ett utkast,
- leverantören bara har teknisk åtkomst,
- informationen inte används för träning,
- användaren tänker radera konversationen efteråt.

Sekretessen skyddar uppgiften, inte filformatet eller användargränssnittet.

Teknisk bearbetning och teknisk lagring

Offentlighets- och sekretesslagen innehåller en sekretessbrytande bestämmelse som kan göra det möjligt att lämna sekretessbelagda uppgifter till en extern aktör som för myndighetens räkning **endast** tekniskt bearbetar eller tekniskt lagrar informationen, om utlämnandet inte är olämpligt med hänsyn till omständigheterna.

Digg konstaterar att generativa AI-verktyg i vissa fall kan omfattas av denna situation, men att det beror på avtalet, verktygets funktion och användningsområdet och därför måste utredas innan användning.

Det är en viktig nyans: begreppet "molntjänst" eller "AI-tjänst" avgör inte i sig om undantaget är tillämpligt.

Arkitekturfråga: Vad gör leverantören faktiskt med informationen – och enbart för vems räkning?

Säkerhetsskydd: en annan nivå av krav

Om AI-lösningen berör säkerhetskänslig verksamhet blir säkerhetsskyddslagen central. Lagen gäller verksamhet av betydelse för Sveriges säkerhet och ställer krav på säkerhetsskyddsanalys och nödvändiga säkerhetsskyddsåtgärder.

Informationssäkerheten ska bland annat förebygga att säkerhetsskyddsklassificerade uppgifter obehörigen röjs, ändras, görs otillgängliga eller förstörs och förebygga skadlig påverkan på informationssystem i säkerhetskänslig verksamhet.

Detta är inte bara en fråga om att undvika att skriva hemliga uppgifter i en publik chatbot. En extern AI-lösning kan även ge en annan aktör tillgång till:

- säkerhetskänsliga informationssystem,
- teknisk arkitektur,
- driftmönster,
- loggar,
- metadata,
- funktioner vars påverkan kan skada säkerhetskänslig verksamhet.

När en annan aktör kan få relevant tillgång kan säkerhetsskyddsavtal, särskild säkerhetsskyddsbedömning, lämplighetsprövning och andra krav aktualiseras.

Röd signal: AI-lösningen berör säkerhetskänslig verksamhet och säkerhetsskyddsfrågan är ännu inte analyserad.

RAG gör inte informationen juridiskt "lokal"

Retrieval-augmented generation, RAG, används ofta för att låta en språkmodell svara med stöd av myndighetens egna dokument.

Det kan vara en bra säkerhets- och kvalitetsarkitektur, men RAG löser inte automatiskt de rättsliga frågorna.

Arkitekten behöver fortfarande veta:

- vilka dokument som indexeras,
- vilka användare som får söka i vilka informationsmängder,
- om embeddings innehåller eller kan härleda skyddad information,

- var index och embeddings lagras,
- vilka textutdrag som skickas till modellen,
- om modellen eller leverantören loggar dessa utdrag,
- om åtkomstkontrollen i källsystemet följer med hela vägen till AI-svaret.

Ett vanligt arkitekturfel är att ett AI-lager skapar en ny sökväg som kringgår den behörighetsmodell som redan finns i källsystemen.

Arkitekturfråga: Kan en användare genom AI:n få information som samma användare inte får läsa direkt i källsystemet?

Träning, finjustering och återanvändning är nya ändamål att analysera

Det är stor skillnad mellan att tillfälligt använda information som input och att låta den användas för:

- träning av en modell,
- finjustering,
- utvärdering,
- leverantörens produktutveckling,
- framtida analys,
- mänsklig kvalitetsgranskning hos leverantören.

Om personuppgifter ingår kan en sådan återanvändning innebära en ny behandling som måste bedömas mot bland annat ändamålsbegränsning och rättslig grund. Om informationen omfattas av sekretess eller andra skydd kan även utlämnandefrågan förändras.

Därför räcker det inte att fråga om leverantören "tränar modellen". Avtal och teknisk dokumentation behöver visa **alla former av sekundär användning och åtkomst**.

Upphovsrätt kan påverka vilka källor som får användas

När ett AI-system använder stora mängder text, bilder, kod eller annat material behöver arkitekten också fråga om materialet är upphovsrättsligt skyddat och vilken användning som faktiskt sker. Frågan blir särskilt relevant vid modellträning, finjustering, text- och datautvinning och större RAG-lösningar med material som myndigheten inte själv äger rättigheterna till.

Det betyder inte att skyddat material generellt är förbjudet som AI-underlag. Upphovsrättslagen innehåller både ensamrätter och inskränkningar, bland annat regler om text- och datautvinning. Den konkreta bedömningen beror därför på materialet, användningen och vilken rätt eller licens myndigheten har.

Gul signal: lösningen bygger på stora mängder externt material och projektet har bara kontrollerat dataskydd och sekretess, inte användningsrätten till innehållet.

TredjELandsöverföring: fysisk lagringsplats är inte hela frågan

GDPR:s regler om tredjELandsöverföring kan aktualiseras när personuppgifter skickas eller görs tillgängliga för en mottagare utanför EU/EES.

IMY anger uttryckligen att även läsbehörighet från ett tredjELand kan innebära en överföring, även om uppgifterna lagras inom EU/EES. Molnarkitektur måste därför analyseras utifrån faktisk åtkomst, inte enbart datacentrets geografiska adress.

För AI-tjänster behöver man bland annat förstå:

- var leverantören och underleverantörerna är etablerade,
- var support och driftpersonal finns,
- var loggar behandlas,
- om fjärråtkomst från tredjELand förekommer,
- vilka överföringsmekanismer och skyddsåtgärder som används.

Den frågan utvecklas vidare i kapitel 5 om extern AI.

Sektorsspecifik reglering kan sätta snävare gränser

GDPR är inte alltid den enda dataskyddsregeln. Många myndigheter har särskilda register- eller datalagar som anger vilka personuppgifter som får behandlas, för vilka ändamål, vilka sökningar som får göras, vem som får få tillgång och hur länge uppgifter får behandlas.

Det är därför farligt att resonera:

”Vi har rättslig grund enligt GDPR, alltså får vi göra analysen.”

Den sektorsspecifika regleringen kan innehålla ytterligare begränsningar.

Bilaga B visar detta översiktligt för Tullverket, Polismyndigheten och Skatteverket.

En informationskontroll före AI-design

Följande kontroll kan göras innan en AI-lösning designas eller anskaffas:

Kontrollfråga	Om svaret är ja
Förekommer personuppgifter?	Identifiera ändamål, rättslig grund, principer, roller och säkerhetskrav
Förekommer känsliga eller särskilt skyddsvärda personuppgifter?	Höj risknivån och bedöm behov av DPIA och starkare skydd
Omfattas någon uppgift av sekretess eller tystnadsplikt?	Utred om och på vilken grund leverantör eller annan mottagare får ta del av uppgiften
Berör lösningen säkerhetskänslig verksamhet?	Koppla in säkerhetsskyddskompetens innan arkitekturen låses

Kontrollfråga	Om svaret är ja
Ska information indexeras i RAG eller embeddings?	Kontrollera åtkomstmodell, lagring, informationsspridning och livscykel
Ska data användas för träning, finjustering eller leverantörens förbättring?	Behandla detta som en särskild användning som kräver egen analys
Finns åtkomst eller behandling utanför EU/EES?	Utred tredjelandsöverföring och skyddsåtgärder
Finns sektorsspecifik data- eller registerlagstiftning?	Kontrollera dess ändamål, sökregler, åtkomst och lagringstider

Bedömning: grönt, gult eller rött

Grönt

Lösningen arbetar med offentlig eller på annat sätt okänslig information, inga personuppgifter behöver behandlas, och informationsflödet är känt och kontrollerat.

Exempel: generativ AI används för att språkgranska redan publicerad myndighetstext i en godkänd tjänst.

Gult

Personuppgifter, intern information, extern leverantör, RAG, omfattande loggning eller tredjelandsåtkomst förekommer. Användningen kan mycket väl vara tillåten, men informationsflödet och skyddsåtgärderna behöver analyseras innan lösningen låses.

Rött

Sekretessbelagda eller säkerhetsskyddsklassificerade uppgifter riskerar att lämnas till en mottagare utan klarlagt rättsligt stöd, eller säkerhetskänslig verksamhet berörs utan genomförd säkerhetsskyddsbedömning.

Färgen beskriver behovet av analys – inte hur ”bra” eller ”dålig” AI-tekniken är.

Sammanfattning

När en myndighet använder AI är informationsfrågan ofta mer avgörande än modellfrågan.

Arkitekten bör därför:

1. kartlägga informationsflödet,
2. identifiera personuppgifter och tillämpliga dataskyddsregler,
3. kontrollera ändamål och dataminimering,
4. identifiera sekretess och tystnadsplikt,
5. kontrollera om säkerhetsskydd aktualiseras,
6. förstå vad RAG, loggar, embeddings och träning faktiskt gör med informationen,
7. identifiera leverantörs- och tredjelandsåtkomst,
8. kontrollera sektorsspecifika regler.

Den viktigaste tumregeln är:

Fråga inte bara om AI får användas. Fråga om just dessa uppgifter får behandlas för just detta ändamål, på just detta sätt och av just dessa aktörer.

Nästa kapitel går vidare från informationen till konsekvenserna för människor: **vad förändras när AI används i bedömningar, handläggning och myndighetsbeslut?**

Viktigaste källorna

- Europaparlamentets och rådets förordning (EU) 2016/679, GDPR: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- Lag (2018:218) med kompletterande bestämmelser till EU:s dataskyddsförordning: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-2018218-med-kompletterande-bestammelser_sfs-2018-218/
- IMY, *GDPR och AI*: <https://www.imy.se/verksamhet/ai/gdpr-och-ai/>
- IMY, *Grundläggande principer enligt GDPR*: <https://www.imy.se/verksamhet/dataskydd/det-har-galler-enligt-gdpr/grundlaggande-principer>
- IMY, *Konsekvensbedömning enligt GDPR*: <https://www.imy.se/verksamhet/dataskydd/det-har-galler-enligt-gdpr/konsekvensbedomning/>
- IMY, *Överföring av personuppgifter till tredjeland*: <https://www.imy.se/verksamhet/dataskydd/det-har-galler-enligt-gdpr/overforing-till-tredje-land/>
- Digg/IMY, *Säkerställ sekretess vid användning av generativ AI*: <https://www.digg.se/ai-for-offentlig-forvaltning/riktlinjer-for-generativ-ai/sakerstall-sekretess-vid-anvandning-av-generativ-ai>
- Offentlighets- och sekretesslag (2009:400), särskilt 10 kap. 2 a §: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/offentlighets-och-sekretesslag-2009400_sfs-2009-400/
- Säkerhetsskyddslag (2018:585): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/sakerhetsskyddslag-2018585_sfs-2018-585/
- Säkerhetsskyddsförordning (2021:955): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/sakerhetsskyddsforordning-2021955_sfs-2021-955/

Kapitel 4

När AI påverkar människor och myndighetsbeslut

När AI påverkar hur en människa bedöms, prioriteras eller får sina rättigheter och skyldigheter bestämda ökar kraven på rättslig och organisatorisk kontroll.

AI kan fortfarande användas i handläggning och beslutsstöd. Men ju närmare lösningen kommer ett beslut om en enskild, desto viktigare blir rättsligt stöd, saklighet, mänsklig kontroll, dokumentation och möjlighet till efterhandskontroll.

En praktisk princip är:

Ju större betydelse AI-resultatet får för en människas situation, desto mindre bör arkitekturen förlita sig på att någon "kan kontrollera" resultatet i efterhand. Kontrollen måste vara verklig, möjlig och inbyggd i processen.

Skilj mellan arbetsstöd, beslutsstöd och beslut

Ordet *beslutsstöd* används lätt för mycket olika lösningar. För en rättslig och arkitekturell bedömning behöver användningen beskrivas mer precist.

En förenklad skala är:

1. AI förbättrar språk eller formatering.
2. AI sammanfattar information som handläggaren själv kan kontrollera.
3. AI söker fram eller strukturerar relevant material.
4. AI rekommenderar en åtgärd eller ett beslut.
5. AI rangordnar, riskklassificerar eller flaggar personer eller ärenden.
6. AI avgör en fråga utan meningsfull mänsklig bedömning.

De första stegen kan ofta hanteras som vanligt arbetsstöd. De senare stegen kräver normalt betydligt mer analys.

Det avgörande är inte vad systemet kallas i produktbeskrivningen utan **vilken faktisk betydelse outputen får i processen.**

Förvaltningslagen tillåter automatiserade beslut - men ställer fortfarande krav

Förvaltningslagen anger att ett beslut kan fattas av en befattningshavare, av flera gemensamt eller automatiserat. Svensk förvaltningsrätt innehåller alltså inget generellt förbud mot automatiserat beslutsfattande.

Samtidigt gäller de grundläggande kraven på myndigheten. En myndighet får bara vidta åtgärder som har stöd i rättsordningen och ska vara saklig och opartisk. Ingrepp i enskildas intressen ska dessutom vara proportionerliga.

Förvaltningslagen kräver också bland annat att:

- ärenden handläggs enkelt, snabbt och kostnadseffektivt utan att rättssäkerheten eftersätts,
- uppgifter som kan ha betydelse för ett beslut dokumenteras när det behövs,
- skriftliga beslut dokumenteras,
- beslut som påverkar någon på ett inte obetydligt sätt normalt får en klagande motivering.

Det betyder att automatisering inte minskar myndighetens ansvar för beslutets innehåll eller för processen som leder fram till det.

Arkitekturfråga: Kan myndigheten förklara vilka föreskrifter och vilka omständigheter som varit avgörande för beslutet även när AI har påverkat underlaget?

GDPR artikel 22 träffar en snävare men viktig situation

När personuppgifter behandlas behöver även GDPR analyseras. Artikel 22 ger den registrerade rätt att inte bli föremål för ett beslut som:

- bygger **enbart** på automatiserad behandling, inklusive profilering, och
- får rättsliga följder eller på liknande sätt påverkar personen betydligt.

Bestämmelsen har undantag, bland annat när behandlingen är tillåten enligt unionsrätt eller nationell rätt och det finns lämpliga skyddsåtgärder.

Två saker är särskilt viktiga för arkitekten.

All automatisering omfattas inte av artikel 22

En AI-modell som exempelvis sorterar dokument eller ger ett förslag som en handläggare självständigt bedömer behöver inte innebära att beslutet är *enbart automatiserat*.

Men en människa i processen gör inte automatiskt behandlingen mänskligt styrd i praktiken. Om handläggaren saknar tid, information, kompetens eller faktisk möjlighet att frånga modellens resultat kan processen i realiteten bli starkt automatiserad.

Mänsklig kontroll måste kunna påverka utfallet

Om mänsklig kontroll ska vara en skyddsåtgärd behöver den vara mer än ett knapptryck på "godkänn".

Arkitekturen bör därför stödja att handläggaren kan:

- se vilket underlag AI-resultatet bygger på,
- förstå resultatets begränsningar,
- identifiera när resultatet är osäkert eller avvikande,

- hämta fram ursprungliga källor,
- bortse från eller ändra AI-resultatet,
- dokumentera en annan bedömning utan tekniska hinder.

Detta blir också viktigt enligt AI-förordningens regler om mänsklig kontroll för högrisk-AI.

AI-förordningen kan träffa även beslutsstöd med människa i loop

Det är ett vanligt missförstånd att ett AI-system undgår högriskklassning bara för att en människa fattar det slutliga beslutet.

AI-förordningen klassificerar vissa användningar som högrisk utifrån **vad systemet är avsett att användas till och vilken betydelse det får**, inte bara efter om slutbeslutet formellt fattas av en människa.

Exempel i Annex III omfattar bland annat AI som används för:

- tillgång till vissa väsentliga offentliga stöd och tjänster,
- rekrytering och personalledning,
- vissa brottsbekämpande ändamål,
- migration, asyl och gränskontroll,
- rättskipning.

EU-kommissionens **utkast till riktlinjer** om högriskklassificering visar exempelvis att ett system som flaggar ansökningar om offentliga stöd för fördjupad kontroll kan vara högrisk även om en mänsklig handläggare senare gör bedömningen. Utkastet är inte bindande och de slutliga riktlinjerna är ännu inte antagna i september 2026. Flaggan kan i sig påverka granskning, fördröjning eller tillgång till förmånen.

På samma sätt kan ett AI-baserat juridiskt stöd som ger individanpassade rekommendationer till en handläggare vara högrisk om rekommendationen materiellt påverkar bedömningen av en persons rätt till en väsentlig offentlig tjänst.

Arkitekturkonsekvens: fråga inte bara *vem som trycker på besluts-knappen*. Fråga **hur mycket AI-resultatet styr vägen fram till beslutet**.

Det finns också undantag för vissa begränsade stödfunktioner

Alla AI-funktioner som används i ett känsligt ärendeflöde blir inte automatiskt högrisk.

AI-förordningen innehåller undantag för vissa system som endast utför begränsade processuella eller förberedande uppgifter och inte materiellt påverkar beslutsresultatet.

EU-kommissionens **utkast till riktlinjer** innehåller bland annat exempel där översättning eller tal-till-text i ett ärende kan falla utanför högriskklassningen när funktionen är rent stödande och handläggaren själv har möjlighet att kontrollera det relevanta innehållet.

Det gör arkitekturens avgränsning viktig. En lösning som bara sammanfattar ett dokument är något annat än en lösning som använder samma dokument för att föreslå om en person ska få eller nekas en förmån.

Mänsklig kontroll är en funktion - inte en organisationsruta

När de relevanta högriskreglerna blir tillämpliga kräver AI-förordningen att mänsklig kontroll faktiskt kan utövas. Den som har kontrolluppgiften behöver ha tillräcklig kompetens, utbildning, befogenhet och stöd. För Annex III-fallen börjar dessa högriskregler tillämpas den 2 december 2027.

Systemet ska, i proportion till risken, göra det möjligt för personen att bland annat:

- förstå AI-systemets kapacitet och begränsningar,
- följa dess funktion,
- upptäcka fel och avvikelser,
- vara medveten om automation bias,
- tolka resultatet korrekt,
- bortse från, åsidosätta eller ändra resultatet,
- ingripa i eller stoppa systemets användning när det behövs.

Detta är en tydlig arkitekturfråga. En process är inte "human-in-the-loop" bara för att en människa finns ritad mellan två systemkomponenter.

Gul signal: handläggaren förväntas kontrollera AI-resultatet men saknar tillgång till källor, osäkerhetsinformation eller möjlighet att avvika från rekommendationen.

Generativ AI kräver särskild försiktighet vid beslut

Digg och IMY rekommenderar att generativ AI används med stor försiktighet i beslutsfattande och att den inte tillåts fatta helt självständiga beslut som direkt påverkar människor.

Skälen är praktiska såväl som rättsliga. Generativa modeller kan:

- hallucinera fakta,
- utelämna relevant information,
- formulera osäkra slutsatser med hög språklig säkerhet,
- ge olika svar på liknande frågor,
- vara svåra att använda som ensam grund för en fullständig beslutsmotivering.

Det betyder inte att generativ AI saknar plats i handläggning. Den kan exempelvis vara värdefull för att sammanfatta material, hitta relevanta avsnitt eller föreslå struktur. Men ju mer outputen påverkar själva bedömningen, desto större blir behovet av kontrollerbara källor och självständig mänsklig prövning.

Saklighet och opartiskhet måste gälla även när modellen gör urvalet

Förvaltningslagens krav på saklighet och opartiskhet försvinner inte när ett statistiskt eller AI-baserat system används som mellanled.

Problem kan uppstå om en modell exempelvis:

- tränats på historiska beslut som innehåller systematiska skevheter,
- använder variabler som fungerar som indirekta proxyer för skyddade egenskaper,
- fungerar sämre för vissa grupper,
- ger olika felmarginaler beroende på språk, namn, ålder eller andra egenskaper,
- prioriterar vissa ärenden till kontroll på ett sätt som inte kan motiveras sakligt.

Diskrimineringslagen kan dessutom bli relevant när användningen sker inom lagens tillämpningsområden, exempelvis rekrytering. Diskrimineringsombudsmannen har särskilt uppmärksammat risken för diskriminering i automatiserade urvalsprocesser och vikten av att även upphandlade lösningar granskas ur diskrimineringsperspektiv.

Arkitekturfråga: Har vi testat systemets resultat för olika relevanta grupper och typer av ärenden, eller bara mätt genomsnittlig träffsäkerhet?

Felprocent är inte samma sak som acceptabel risk

Ett system med 99 procents träffsäkerhet kan låta mycket bra. Men om det används för hundratusentals ärenden kan en procent fel innebära ett stort antal felaktigt bedömda personer.

Dessutom är genomsnittlig träffsäkerhet ofta otillräcklig. Arkitekten behöver fråga:

- Vilken typ av fel gör systemet?
- Vem drabbas av falska positiva respektive falska negativa resultat?
- Är felen jämnt fördelade mellan relevanta grupper?
- Vad händer med personen när systemet har fel?
- Hur snabbt kan felet upptäckas och rättas?
- Finns en fungerande väg för mänsklig omprövning?

Riskbedömningen måste alltså koppla teknisk kvalitet till **konsekvensen av felet**.

Profilering och riskurval kan påverka människor före ett formellt beslut

AI-användning behöver inte mynna ut i ett formellt myndighetsbeslut för att få betydelse för en person.

Ett system kan exempelvis avgöra:

- vilka ärenden som granskas först,

- vilka personer som väljs ut för kontroll,
- vilka ansökningar som får fördjupad granskning,
- vilka signaler en handläggare ser först,
- vilka ärenden som automatiskt betraktas som avvikande.

Sådana mellanbeslut kan skapa faktisk påverkan även om den slutliga rättsliga bedömningen görs senare av en människa.

För arkitekten är det därför bättre att modellera **hela beslutskedjan** än att bara dokumentera slutpunkten.

Dokumentera det som faktiskt påverkade beslutet

Om ett AI-resultat har betydelse för ett ärende behöver myndigheten kunna bedöma hur det ska dokumenteras utifrån bland annat förvaltningsrätt, offentlighet och arkivregler.

Det kan i praktiken behövas spårbarhet för:

- vilken modell eller systemversion som användes,
- vilket underlag som gavs till systemet,
- vilket resultat systemet gav,
- vilka källor eller data resultatet byggde på,
- vilka regler eller tröskelvärden som påverkade resultatet,
- hur handläggaren använde eller frångick resultatet.

Hur mycket som behöver sparas beror på användningen och övrig reglering. Men ett system som påverkar viktiga bedömningar utan att myndigheten i efterhand kan rekonstruera vad som hände skapar en tydlig rättssäkerhetsrisk.

Detta utvecklas vidare i kapitel 6.

En kontroll före AI-stött beslutsfattande

Kontrollfråga	Varför den är viktig
Påverkar AI-resultatet en fysisk persons rättighet, skyldighet, prioritet eller behandling?	Avgör hur högt riskläget bör sättas
Är resultatet endast förberedande, eller påverkar det materiellt bedömningen?	Viktigt för AI-förordningens klassificering
Behandlas personuppgifter?	Aktiverar GDPR och eventuellt artikel 22
Är beslutet helt automatiserat eller finns verklig mänsklig prövning?	Centralt för GDPR och rättssäkerheten
Kan handläggaren förstå och frånga AI-resultatet?	Avgör om mänsklig kontroll är reell
Kan myndigheten motivera beslutet utan att hänvisa till en ogenomskinlig modell?	Förvaltningsrättslig motivering och möjlighet till rättelse/överklagande
Har resultatens kvalitet testats för relevanta grupper och typer av ärenden?	Saklighet, likabehandling och diskrimineringsrisk

Kontrollfråga	Varför den är viktig
Finns möjlighet att upptäcka och korrigera fel?	Begränsar konsekvenserna av felaktiga AI-resultat
Finns sektorsspecifika regler för urval, profilering eller automatiserade beslut?	Generella regler kan kompletteras eller begränsas
Är det tydligt vad som behöver loggas och dokumenteras?	Spårbarhet och efterhandskontroll

Bedömning: grönt, gult eller rött

Grönt

AI används för en begränsad stöduppgift där resultatet är enkelt att kontrollera och inte materiellt styr bedömningen av en person.

Exempel: AI sammanfattar ett långt underlag, men handläggaren använder och kontrollerar originalhandlingarna innan bedömningen görs.

Gult

AI rekommenderar, prioriterar, klassificerar, flaggar eller på annat sätt påverkar en bedömning av människor. Användningen kan vara tillåten men behöver analyseras avseende bland annat AI-förordningen, dataskydd, rättsligt stöd, bias, mänsklig kontroll och dokumentation.

Rött

AI fattar eller styr beslut med betydande konsekvenser utan att nödvändigt rättsligt stöd, fungerande mänsklig kontroll eller andra obligatoriska skyddsåtgärder är klarlagda. Detsamma gäller om användningen träffas av ett förbud i AI-förordningen.

Rött betyder inte att varje avancerat beslutsstöd är förbjudet. Det betyder att arkitekturen inte bör gå vidare som en vanlig teknisk implementation innan den rättsliga och verksamhetsmässiga ramen är klar.

Arkitektens viktigaste uppgift

Arkitektens uppgift är inte att ensam avgöra om ett automatiserat beslut är lagligt eller om en viss AI-användning är diskriminerande.

Den viktigaste uppgiften är att göra användningen **bedömningsbar**.

Det kräver att arkitekturbeskrivningen visar:

- vilken funktion AI:n har,
- vilken information den använder,
- vad outputen betyder i processen,
- hur människor påverkas,
- vilken mänsklig kontroll som finns,
- hur resultat kan ifrågasättas och ändras,
- hur beslut och underlag dokumenteras.

När det är tydligt kan jurister, dataskyddsombud, verksamhet, säkerhetsfunktion och andra specialister göra sina respektive bedömningar. När det är otydligt riskerar både teknik- och juridikdiskussionen att fastna i abstrakta frågor om "AI" i stället för den faktiska användningen.

Viktigaste källorna

- Förvaltningslag (2017:900), särskilt 5, 9, 27, 28, 31 och 32 §§: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/forvaltningslag-2017900_sfs-2017-900/
- Förordning (EU) 2016/679 (GDPR), särskilt artikel 22: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- AI-förordningen – AI Act Explorer, särskilt artiklarna 14 och 26 samt Annex III: <https://ai-act-service-desk.ec.europa.eu/en/ai-act-explorer>
- EU-kommissionen – **utkast** till riktlinjer och exempel för klassificering av högrisk-AI (ej bindande; slutliga riktlinjer ännu inte antagna per 2026-09-07): <https://ai-act-service-desk.ec.europa.eu/en/guideline-explorer>
- Digg/IMY – Beslut med stöd av generativ AI bör ha mänsklig kontroll: <https://www.digg.se/ai-for-offentlig-forvaltning/riktlinjer-for-generativ-ai/beslut-med-stod-av-generativ-ai-bor-ha-mansklig-kontroll>
- Diskrimineringsombudsmannen – exempel om AI och automatiserade urval: <https://e-guide.do.se/aktiva-atgarder/exempel/rekrytering-och-befordran/artificiell-intelligens-ai>
- Diskrimineringslag (2008:567): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/diskrimineringslag-2008567_sfs-2008-567/

Kapitel 5

När någon annan tillhandahåller AI:n

Myndigheter använder ofta AI genom externa tjänster: SaaS, API:er, AI-funktioner i befintliga system eller leverantörsdrift.

Det kan vara både effektivt och lämpligt. Men när kontroll flyttas utanför myndigheten behöver arkitekten förstå inte bara **vad AI-funktionen gör**, utan också **vem som behandlar informationen, var den behandlas, vilka underleverantörer som används och vilka rättigheter leverantören får till data och resultat**.

En praktisk princip är:

En extern AI-tjänst bör bedömas som ett informationsflöde och ett beroende - inte bara som en funktion.

Utgå från behovet

Det är lätt att börja med frågan: *Kan vi använda produkt X?* En bättre startpunkt är:

- vilket verksamhetsbehov ska lösas,
- vilken information behöver behandlas,
- vilka personer eller beslut kan påverkas,
- vilken tillgänglighet och kvalitet behövs,
- vilka rättsliga och säkerhetsmässiga begränsningar gäller,
- vilken kontroll behöver myndigheten ha över data, modell och leverantör.

Digg och IMY rekommenderar att offentlig förvaltning utgår från verksamhetens behov när generativ AI anskaffas. Färdiga tjänster kan vara lämpliga för enklare användning och kompetenshöjning, medan mer verksamhetskritiska behov kan kräva tydligare kravställning och större kontroll.

Detta är viktigt för arkitekten eftersom en produkt som fungerar bra i en demonstration inte automatiskt är lämplig för myndighetens verkliga informationsmängder och processer.

En AI-tjänst är ofta flera tjänster samtidigt

Det som för användaren ser ut som en enda AI-tjänst kan i praktiken bestå av flera delar:

- användargränssnitt,
- API-gateway,
- identitets- och behörighetstjänst,
- loggning och telemetri,
- modellleverantör,
- databas eller vektordatabas,

- modereringstjänster,
- support- och övervakningsfunktioner,
- underleverantörer för drift eller analys.

Det betyder att frågan *“var ligger tjänsten?”* ofta är för enkel.

Arkitekten behöver i stället kartlägga **hela behandlingskedjan**:

1. Var skickas prompten?
2. Var lagras den?
3. Vem kan administrera tjänsten?
4. Var behandlas bilagor och RAG-data?
5. Var lagras loggar och metadata?
6. Används en separat modellleverantör?
7. Finns supportåtkomst från andra länder?
8. Kan informationen användas för leverantörens egna ändamål?

Om leverantören inte kan ge tillräckligt tydliga svar är det i sig en arkitekturell risk.

Upphandling handlar om mer än pris och funktion

Lag (2016:1145) om offentlig upphandling, LOU, gäller för många av de inköp en myndighet gör. AI förändrar inte grundprinciperna för offentlig upphandling.

Digg rekommenderar att offentliga aktörer först kontrollerar befintliga avtal och ramavtal och, om de inte täcker behovet, genomför upphandling enligt gällande regler. Licens- och avtalsvillkor behöver analyseras både inför anskaffningen och under användningen.

För AI-lösningar behöver kravställningen ofta vara bredare än vid ett vanligt funktionsköp.

Exempel på frågor som kan behöva bli krav eller avtalsvillkor:

- Vilka modeller får leverantören använda?
- Får modellen eller modellversionen bytas utan godkännande?
- Var får data behandlas och lagras?
- Vilka underleverantörer får användas?
- Hur meddelas förändringar i underleverantörskedjan?
- Får myndighetens data användas för träning eller förbättring av leverantörens modeller?
- Hur länge sparas promptar, svar, filer och loggar?
- Kan myndigheten få tillgång till relevanta loggar?
- Vilka säkerhetskontroller kan myndigheten verifiera?
- Hur hanteras incidenter?
- Vilka krav gäller vid avveckling och export av data?
- Hur kan myndigheten byta leverantör utan orimliga kostnader eller informationsförlust?

Arkitekturfråga: Är de krav som behövs för att lösningen ska vara laglig och kontrollerbar faktiskt möjliga att skriva in i avtalet och följa upp i praktiken?

Personuppgiftsansvaret försvinner inte vid outsourcing

När myndigheten använder en extern AI-tjänst för sitt uppdrag är myndigheten som utgångspunkt fortfarande personuppgiftsansvarig för den personuppgiftsbehandling som sker för myndighetens ändamål.

Om leverantören behandlar personuppgifter för myndighetens räkning kan leverantören vara personuppgiftsbiträde. Då krävs normalt ett personuppgiftsbiträdesavtal och myndigheten måste kunna säkerställa att behandlingen uppfyller GDPR.

Det finns en viktig komplikation med AI-tjänster: leverantören kan vilja använda uppgifterna för **egna ändamål**, exempelvis för att träna eller förbättra en grundmodell.

Digg/IMY framhåller att en leverantör som behandlar uppgifter enbart för verksamhetens räkning kan vara biträde. Om leverantören däremot har ett eget ändamål, till exempel vidareutveckling av grundmodellen med myndighetens personuppgifter, kan rollfördelningen förändras.

Detta gör avtalsvillkor om datanyttjande särskilt viktiga.

Röd signal: leverantören förbehåller sig en generell rätt att använda myndighetens indata, filer eller konversationer för egen modellträning och myndigheten behandlar uppgifter som inte får användas för detta ändamål.

“Vi tränar inte på era data” löser inte hela frågan

Det är positivt om leverantören inte använder myndighetens data för modellträning, men det är bara en del av bedömningen.

Myndigheten behöver fortfarande förstå:

- om data lagras,
- hur länge data lagras,
- om loggar innehåller personuppgifter eller sekretesskyddade uppgifter,
- om supportpersonal kan få åtkomst,
- vilka underleverantörer som får åtkomst,
- om data kopieras för säkerhetskopiering,
- om metadata används för andra ändamål,
- om data kan behandlas utanför EU/EES.

Det är därför bättre att fråga **“hur behandlas vår information genom hela livscykeln?”** än enbart **“tränar ni på vår data?”**.

TredjELandsfrågan handlar om åtkomst, inte bara datacenter

I kapitel 3 konstaterade vi att personuppgifter kan överföras till tredjELand även utan att ett primärt datacenter ligger där. Åtkomst från ett land utanför EU/EES kan i vissa situationer innebära en tredjELandsöverföring.

För en extern AI-tjänst behöver därför frågor om:

- driftplats,
- administratörsåtkomst,
- support,
- underleverantörer,
- incidenthantering,
- rättsliga krav på leverantören i dess hemland

analyseras tillsammans.

Det räcker alltså inte med ett marknadsföringspåstående om “EU-region” om andra delar av tjänsten fortfarande innebär åtkomst från tredjELand.

Gul signal: tjänsten driftas i EU men leverantören kan inte tydligt beskriva vilka support- och administrationsflöden som kan nå informationen.

Sekretess kräver en separat bedömning

Att ett personuppgiftsbiträdesavtal finns betyder inte automatiskt att sekretessreglerna är uppfyllda.

Offentlighets- och sekretesslagen och annan tystnadspliktsreglering måste bedömas separat. Digg rekommenderar uttryckligen att offentliga aktörer utreder om informationsöverföring till leverantör eller mellanhand är tillåten och säkerställer att uppgifter som ska stanna inom verksamheten inte lämnas ut utan rättsligt stöd.

Arkitekten behöver därför kunna skilja på minst tre frågor:

1. Får myndigheten behandla personuppgifterna på detta sätt?
2. Får uppgifterna lämnas till den externa aktören?
3. Är säkerhetsnivån tillräcklig för informationens skyddsvärde?

Ett ja på den första frågan innebär inte automatiskt ja på de två andra.

Säkerhetsskydd kan förändra hela anskaffningen

Om AI-lösningen berör säkerhetskänslig verksamhet kan säkerhetsskyddslagen utlösa krav som går långt utöver en vanlig moln- eller SaaS-bedömning.

Det kan bland annat påverka:

- vilka leverantörer som över huvud taget är möjliga,
- vilken information de får ta del av,
- hur systemet får driftas,
- vilka kontroller som måste göras före anskaffning,
- behov av säkerhetsskyddsavtal,
- krav på åtkomstkontroll och personalsäkerhet.

Röd signal: en leverantör ska få åtkomst till säkerhetsskyddsklassificerade uppgifter eller till säkerhetskänslig verksamhet utan att säkerhetsskyddsfrågan har analyserats tidigt i anskaffningen.

AI-förordningen gör leverantörskedjan juridiskt relevant

AI-förordningen skiljer mellan flera roller, bland annat provider och deployer. En myndighet som använder ett färdigt AI-system är ofta deployer, medan leverantören är provider.

Men rollerna är inte statiska.

En organisation som gör en väsentlig ändring av ett högrisk-AI-system eller sätter sitt eget namn på systemet kan under vissa förutsättningar själv få provider-ansvar.

Det innebär att en myndighet inte bör anta att **“vi köper bara tjänsten”** alltid betyder att alla regulatoriska skyldigheter ligger hos leverantören.

För högrisk-AI måste deployern dessutom kunna använda systemet enligt instruktionerna, ordna kompetent mänsklig kontroll och uppfylla andra egna skyldigheter. Det förutsätter att avtalet och tekniken ger myndigheten den information och kontroll som krävs.

Arkitekturfråga: Ger leverantören tillräcklig dokumentation, loggning och kontroll för att myndigheten ska kunna fullgöra sina egna skyldigheter?

Versionsbyten kan ändra riskbilden

AI-tjänster förändras ofta snabbare än traditionella IT-system. Leverantören kan byta:

- grundmodell,
- systemprompt,
- säkerhetsfilter,
- verktygsintegrationer,
- lagringspolicy,
- underleverantörer,
- region för behandling,
- funktioner i användargränssnittet.

En myndighet kan därför ha godkänt en lösning som senare ändras på ett sätt som påverkar:

- informationssäkerhet,
- dataskydd,
- kvalitet,
- förklarbarhet,
- AI Act-klassificering,
- avtalsenlighet.

Avtalet och förvaltningsmodellen behöver därför hantera förändringar över tid.

Exempel på lämpliga kontrollpunkter är:

- krav på förhandsinformation om väsentliga förändringar,
- möjlighet att stoppa eller avvisa en förändring,
- test innan ny modellversion tas i bruk,
- dokumenterad omprövning av riskbedömning,
- tydlig ansvarsfördelning mellan verksamhet, IT, juridik och säkerhet.

Loggar är både en tillgång och en risk

Loggar kan behövas för:

- felsökning,
- spårbarhet,
- incidentutredning,
- uppföljning av modellkvalitet,
- kontroll av mänsklig användning,
- efterlevnad av AI-förordningen.

Samtidigt kan loggar innehålla:

- promptar,
- personuppgifter,
- sekretessbelagda uppgifter,
- modellresultat,
- användaridentiteter,
- känslig metadata.

Arkitekten behöver därför behandla loggningen som en egen informationsmängd med egna regler för behörighet, lagring, gallring och export.

Vanligt misstag: att kräva "full loggning" utan att samtidigt definiera vem som får läsa loggarna och hur länge de får sparas.

Exit är en del av säkerheten

Regeringens molnpolicy för offentlig förvaltning från 2026 betonar bland annat minskat beroende, bättre kontroll över data och möjligheten att välja och byta digitala lösningar.

Det är särskilt relevant för AI, där beroendet inte bara kan ligga i infrastrukturen utan också i:

- proprietära promptformat,
- embeddings,
- vektordatabaser,
- leverantörsspecifika agenter,
- finjusteringar,
- utvärderingsdata,
- loggar och historik,
- modellbeteende som byggts in i verksamhetsprocessen.

En fungerande exitplan bör därför besvara:

- Vilken data kan exporteras?
- I vilket format?
- Kan RAG-index byggas om hos en ny leverantör?
- Vad händer med historiska konversationer och loggar?
- Hur verifieras radering hos den gamla leverantören?
- Kan verksamheten fortsätta om leverantören stänger en modell med kort varsel?
- Hur stor del av lösningen är portabel?

Arkitekturprincip: undvik att göra verksamhetskritiska processer beroende av egenskaper som endast en leverantör kan tillhandahålla om det inte är ett medvetet och accepterat beslut.

Leverantörslåsning är inte automatiskt fel

All leverantörsberoende är inte dåligt. Ibland kan en specifik tjänst ge så stora fördelar att beroendet är motiverat.

Det viktiga är att beroendet är **synligt och beslutat**, inte något som upptäcks när myndigheten vill byta tjänst.

Arkitekten bör därför beskriva:

- vilka delar som är standardiserade,
- vilka delar som är leverantörsspecifika,
- kostnaden för byte,
- vilken data som riskerar att gå förlorad,
- vilka juridiska eller säkerhetsmässiga antaganden som är knutna till leverantören.

Det gör det möjligt för beslutsfattare att väga innovation mot långsiktig kontroll.

En enkel leverantörskontroll för arkitekten

Före beslut om extern AI kan arkitekten använda följande frågor.

1. Behov

- Vilket konkret problem löser tjänsten?
- Finns enklare alternativ med lägre risk?

2. Information

- Vilka uppgifter skickas till tjänsten?
- Förekommer personuppgifter, sekretess eller säkerhetskänslig information?

3. Dataflöde

- Var behandlas data?
- Vilka underleverantörer och supportfunktioner kan få åtkomst?

4. Ändamål

- Behandlar leverantören data endast för myndighetens räkning?
- Får uppgifter användas för modellträning, produktutveckling eller andra egna ändamål?

5. Avtal

- Finns rätt avtal och personuppgiftsbiträdesavtal?
- Regleras underleverantörer, incidenter, loggar, ändringar och radering?

6. AI-förordningen

- Vilken roll har myndigheten respektive leverantören?
- Kan tjänsten vara högrisk eller omfattas av transparenskrav?
- Får myndigheten den dokumentation som behövs?

7. Förändringar

- Kan leverantören byta modell eller villkor utan att myndigheten hinner göra en ny bedömning?

8. Exit

- Kan data och funktion flyttas till en annan lösning?
- Finns en plan om tjänsten försvinner eller blir olämplig?

Bedömning: grönt, gult eller rött

Grönt - normalt möjligt

Exempel:

- lågkänslig information,
- tydligt avtal,
- kända underleverantörer,
- ingen otillåten vidareanvändning av data,
- hanterad tredjelandfråga,
- dokumenterad exit,
- myndigheten kan uppfylla sina egna skyldigheter.

Gult - utred först

Exempel:

- personuppgifter behandlas,
- leverantören använder flera underleverantörer,
- support kan ske från tredjeland,
- modellversionen kan ändras löpande,
- loggningen är otydlig,
- tjänsten ska användas i verksamhetskritiska processer,
- det är svårt att exportera data eller byta leverantör.

Rött - gå inte vidare innan frågan är löst

Exempel:

- sekretesskyddade uppgifter lämnas till leverantör utan rättsligt stöd,
- säkerhetskänslig verksamhet exponeras utan korrekt säkerhetsskyddsanalys,
- leverantören får använda myndighetens uppgifter för egna oförenliga ändamål,
- myndigheten kan inte identifiera var eller av vem informationen behandlas,
- avtalet gör att myndigheten inte kan uppfylla tvingande krav enligt GDPR, AI-förordningen eller annan tillämplig rätt.

Vanliga misstag

“Det är en standardtjänst, så leverantören ansvarar”

Myndigheten ansvarar fortfarande för sin användning och för de behandlingar och beslut som sker inom myndighetens uppdrag.

“Datat ligger i EU, alltså är allt löst”

Driftplats är bara en del av analysen. Support, underleverantörer och administrativ åtkomst kan vara lika viktiga.

“Leverantören tränar inte på vår data”

Bra, men kontrollera även lagring, loggar, supportåtkomst, metadata och underleverantörer.

“Vi kan alltid byta senare”

Byte kan bli svårt om verksamheten byggt in leverantörsspecifika funktioner, embeddings, arbetsflöden eller historik.

“Mänsklig kontroll ligger hos verksamheten”

Det hjälper bara om tjänsten faktiskt ger verksamheten tillräcklig information, funktionalitet och befogenhet för att kontrollen ska fungera.

Sammanfattning

När någon annan tillhandahåller AI:n behöver myndigheten behålla kontroll över **ändamål, information, ansvar och beroenden**.

De viktigaste principerna är:

- börja med verksamhetsbehovet, inte leverantörens produkt,
- kartlägg hela informations- och underleverantörskedjan,
- skilj på dataskydd, sekretess och säkerhetsskydd,
- säkerställ att leverantörens användning av data är tydligt reglerad,
- kravställ dokumentation, loggning och förändringshantering,
- förstå myndighetens egen roll enligt AI-förordningen,
- planera exit redan vid anskaffningen.

En extern AI-tjänst kan vara ett utmärkt sätt att snabbt få tillgång till avancerad AI. Men outsourcing innebär inte outsourcing av myndighetens ansvar.

Viktigaste källorna

- Lag (2016:1145) om offentlig upphandling: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-20161145-om-offentlig-upphandling_sfs-2016-1145/
- Digg/IMY – Ta medvetna beslut om att skaffa generativ AI: <https://www.digg.se/ai-for-offentlig-forvaltning/riktlinjer-for-generativ-ai/ta-medvetna-beslut-om-att-skaffa-generativ-ai>
- Digg/IMY – Köp generativ AI enligt lagen om offentlig upphandling: <https://www.digg.se/ai-for-offentlig-forvaltning/riktlinjer-for-generativ-ai/kop-generativ-ai-enligt-lagen-om-offentlig-upphandling>

- Digg/IMY – Klargör rollfördelningen mellan personuppgiftsansvarig och personuppgiftsbiträde: <https://www.digg.se/ai-for-offentlig-forvaltning/riktlinjer-for-generativ-ai/klargor-rollfordelningen-mellan-personuppgiftsansvarig-och-personuppgiftsbitrade>
- Digg/IMY – Säkerställ sekretess vid användning av generativ AI: <https://www.digg.se/ai-for-offentlig-forvaltning/riktlinjer-for-generativ-ai/sakerstall-sekretess-vid-anvandning-av-generativ-ai>
- AI-förordningen, särskilt artiklarna 25 och 26: <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng>
- Sveriges molnpolicy för offentlig förvaltning (2026): <https://www.regeringen.se/informationsmaterial/2026/05/en-molnpolicy-for-sverige-for-okad-sakerhet-effektivitet-och-innovation-i-den-offentliga-forvaltningen/>

Kapitel 6

Offentlighet, dokumentation och spårbarhet

Dataskydd, sekretess och säkerhet får ofta mest uppmärksamhet. För en svensk myndighet är ytterligare ett perspektiv centralt: **informationen måste kunna hanteras så att offentlighet, dokumentation och efterhandskontroll fungerar.**

AI förändrar inte offentlighetsprincipen. Men tekniken kan göra det svårare att se **vilken information som finns, var den finns, när den har skapats och vad som behöver bevaras.**

En praktisk princip är:

Designa inte bara för att AI ska kunna producera ett resultat. Designa också för att myndigheten i efterhand ska kunna förstå vilken information som användes, vad AI:n gjorde och vilket underlag som faktiskt fick betydelse.

Det betyder inte att varje prompt, token eller teknisk mellanprodukt alltid måste sparas. Det betyder att informationshanteringen behöver analyseras med samma omsorg som själva AI-funktionen.

Offentlighetsprincipen är utgångspunkten

Tryckfrihetsförordningen, TF, ger var och en rätt att ta del av allmänna handlingar. För att avgöra om något är en allmän handling behöver man förenklat bedöma om det är en **handling**, om den **förvaras hos myndigheten** och om den är **inkommen eller upprättad**.

Begreppet handling är teknikneutralt. Det omfattar inte bara traditionella dokument utan också upptagningar som kan läsas, avlyssnas eller uppfattas med tekniska hjälpmedel.

Det gör offentlighetsprincipen direkt relevant för moderna AI-miljöer.

Exempel på information som kan behöva bedömas är:

- promptar,
- AI-genererade svar,
- uppladdade filer,
- resultat från RAG-sökningar,
- loggar,
- klassificeringar och poäng,
- sammanställningar,
- automatiskt skapade beslutsunderlag,
- konfigurationsdata och systeminstruktioner.

Men det följer inte att allt detta automatiskt är allmänna handlingar.

Arkitektens uppgift är därför inte att själv avgöra alla offentlighetsrättsliga gränssfall, utan att utforma lösningen så att myndigheten kan göra bedömningen.

Prompt och svar är inte en särskild juridisk kategori

Det är lockande att fråga: *Är en prompt en allmän handling?* eller *Är svaret från en språkmodell en allmän handling?*

Frågorna är förståeliga men för generella.

En prompt kan exempelvis vara:

- en kort instruktion som skrivs och omedelbart försvinner,
- en sparad del av en chattjänsts historik,
- en sammanställning av uppgifter ur ett ärende,
- en instruktion som ingår i ett dokumenterat arbetsflöde,
- en systemprompt som är en del av myndighetens konfiguration.

På motsvarande sätt kan ett AI-svar vara:

- tillfällig text som aldrig används,
- arbetsmaterial,
- ett underlag som tillför ett ärende sakuppgifter,
- en färdig text som expedieras,
- ett dokumenterat beslutsunderlag,
- data som lagras i en extern molntjänst.

TF:s vanliga kriterier måste därför tillämpas på den konkreta situationen.

Detta är också ett område där rättstillämpningen fortfarande behöver klarläggas. I september 2026 beslutade regeringen om en särskild utredning som bland annat ska analysera i vilken utsträckning upptagningar som genereras eller lagras genom AI-verktyg och externa molntjänster utgör allmänna handlingar. Uppdraget ska redovisas senast den 15 november 2027.

Gul signal: verksamheten använder AI på ett sätt som genererar eller lagrar betydande informationsmängder, men det finns ingen beslutad modell för hur dessa informationsmängder ska klassificeras och hanteras ur offentlighets- och arkivperspektiv.

Förvarad information kan finnas utanför myndighetens egna servrar

För elektroniska upptagningar är det inte bara den fysiska lagringsplatsen som är relevant.

TF anger att en upptagning kan anses förvarad hos en myndighet om den är tillgänglig för myndigheten med tekniska hjälpmedel som myndigheten själv använder.

Det gör en enkel likställning problematisk:

“Informationen ligger hos leverantören, alltså finns den inte hos myndigheten.”

En SaaS- eller molntjänst kan vara tekniskt placerad hos en extern leverantör samtidigt som informationen är tillgänglig för myndigheten genom tjänsten.

För AI-arkitektur innebär det att följande behöver kartläggas:

- vilka informationsmängder myndighetens användare kan nå,
- vilka historikfunktioner tjänsten har,
- vilka sammanställningar som kan genereras,
- hur länge information är tillgänglig,
- om administratörer kan söka eller exportera den,
- vad som ligger hos underleverantörer,
- vad som endast är en teknisk mellanprodukt.

Detta är ytterligare ett skäl till att informationsarkitektur inte bör begränsas till myndighetens egna databaser.

Inkommen och upprättad är avgörande begrepp

En handling blir inte allmän enbart för att den är elektronisk eller förvarad hos myndigheten. Den måste också vara inkommen eller upprättad enligt TF.

Det kan få praktisk betydelse i AI-flöden.

En handling som någon utanför myndigheten skickar in via en AI-baserad kanal kan exempelvis vara inkommen även om AI-systemet först analyserar eller klassificerar innehållet.

Ett AI-genererat underlag inom myndigheten kan i stället behöva bedömas utifrån reglerna om när en handling är upprättad och vad som gäller för minnesanteckningar, utkast och andra handlingar under beredningen.

Det betyder att arkitekturen bör kunna skilja mellan exempelvis:

1. information från den enskilde,
2. automatisk analys av den informationen,
3. internt arbetsmaterial,
4. underlag som tillförs ett ärende,
5. expedierat beslut eller annan färdig handling.

Om allt blandas ihop i en odifferentierad AI-chatt blir både juridisk bedömning och informationsförvaltning svårare.

Tekniska mellanled behöver inte få samma status

TF innehåller särskilda regler för information som endast hanteras för teknisk bearbetning eller teknisk lagring.

Det är viktigt i moln- och AI-arkitektur eftersom samma informationsmängd kan passera flera tekniska komponenter utan att varje komponent automatiskt förändrar handlingens rättsliga status.

Det innebär dock inte att uttrycket **“teknisk bearbetning”** kan användas som en generell etikett på all AI-användning.

En språkmodell som sammanfattar, värderar, klassificerar eller producerar nytt innehåll kan ha en betydligt mer verksamhetsnära funktion än exempelvis ren lagring, formatkonvertering eller säkerhetskopiering.

Arkitekturfråga: Är komponenten faktiskt bara ett tekniskt mellanled, eller utför den en bearbetning som har självständig betydelse för myndighetens verksamhet?

Den frågan bör avgöras tillsammans med juridisk kompetens när gränsdragningen är viktig.

Offentlighet behöver byggas in i informationshanteringen

Offentlighets- och sekretesslagen ställer krav på hur myndigheter organiserar hanteringen av allmänna handlingar. Myndigheten ska bland annat beakta möjligheten att lämna ut handlingar skyndsamt och kunna skilja allmänna handlingar från andra handlingar samtidigt som sekretesskyddet upprätthålls.

Detta är i hög grad en arkitekturfråga.

En AI-lösning bör därför inte skapa ett informationslandskap där:

- ingen vet vilka konversationer som finns,
- bara leverantören kan söka i historiken,
- information inte kan exporteras i begriplig form,
- sekretessbelagda och offentliga uppgifter inte går att skilja åt,
- viktiga resultat försvinner när en användares konto stängs,
- beslutsunderlag saknar koppling till ärendet de hör till.

En bra lösning gör i stället informationsobjektens status och livscykel tydlig.

Diarieföring och registrering är inte samma sak som att spara allt

En vanlig överreaktion är att dra slutsatsen att all AI-interaktion måste diarieföras.

Så enkelt är det inte.

Frågan om registrering beror bland annat på om handlingen är allmän, om den omfattas av sekretess och vilka regler och rutiner som gäller för myndighetens hantering av handlingar.

Arkitektens viktigaste bidrag är därför att säkerställa att lösningen kan:

- identifiera relevant information,
- föra över information till rätt ärende- eller dokumenthanteringssystem,
- bevara nödvändiga metadata,
- tillämpa beslutade gallringsregler,
- separera verksamhetsinformation från rent teknisk telemetri.

Grönt exempel: AI används för språklig förbättring av ett utkast och den färdiga handlingen hanteras i myndighetens ordinarie dokumentprocess.

Gult exempel: handläggare använder en AI-chatt för att analysera ärendehandlingar och viktiga resonemang finns endast kvar i chattens historik.

Arkivlagen börjar där myndighetens handlingar finns

Arkivlagen anger att en myndighets arkiv i huvudsak bildas av myndighetens allmänna handlingar och vissa handlingar som tas om hand för arkivering.

Arkiven ska bevaras, hållas ordnade och vårdas så att de tillgodoser:

- rätten att ta del av allmänna handlingar,
- förvaltningens och rättskipningens informationsbehov,
- forskningens behov.

Det innebär att AI inte får skapa en parallell informationsmiljö som hamnar utanför myndighetens informationsförvaltning.

Om en AI-tjänst producerar handlingar som ska bevaras behöver myndigheten kunna ta hand om dem på ett arkivmässigt hållbart sätt.

Elektroniska handlingar kräver planerad förvaltning

För statliga myndigheter kompletteras arkivlagen av Riksarkivets föreskrifter. RA-FS 2009:1 innehåller föreskrifter och allmänna råd om elektroniska handlingar och är fortfarande giltig, med senare ändringar.

Föreskrifterna förstärker en viktig arkitekturprincip: elektroniska handlingar måste hanteras så att de kan **bevaras, skyddas och förstås över tid**.

I AI-system kan det bland annat innebära behov av dokumentation om:

- format,
- informationsstruktur,
- metadata,
- relationer mellan informationsobjekt,
- exportmöjligheter,

- säkerhetsåtgärder,
- förändringar över tid.

En kommersiell AI-tjänsts egen chattvy är därför sällan en tillräcklig långsiktig arkivlösning.

Gallring måste vara beslutad - inte råka ske

AI-tjänster har ofta egna retentionstider. En leverantör kan exempelvis radera historik efter 30 eller 90 dagar.

Det kan vara bra ur dataminimerings- och säkerhetsperspektiv, men leverantörens standardinställning är inte i sig ett myndighetsbeslut om gallring.

På motsvarande sätt är obegränsad lagring inte automatiskt bättre.

Arkitekten behöver förstå:

- vilka informationsmängder som ska bevaras,
- vilka som får gallras,
- med vilket stöd gallring sker,
- när gallring ska ske,
- om information måste flyttas från AI-tjänsten före gallring,
- vem som ansvarar för att gallringen faktiskt genomförs.

Röd signal: verksamhetskritiska eller arkivpliktiga uppgifter finns endast i en extern AI-tjänst där de automatiskt raderas enligt leverantörens egna standardvillkor.

Spårbarhet är mer än loggning

Det är lätt att likställa spårbarhet med att "slå på loggar".

Men en loggfil är bara värdefull om den hjälper myndigheten att förstå ett förlopp.

För en AI-lösning kan relevant spårbarhet exempelvis innebära att kunna svara på:

- vilket AI-system användes,
- vilken modell eller version användes,
- vilket underlag fick modellen tillgång till,
- vilka instruktioner styrde bearbetningen,
- vilket resultat genererades,
- om en människa granskade eller ändrade resultatet,
- vilket resultat som faktiskt användes i processen,
- när detta skedde.

Behovet varierar kraftigt.

En AI-funktion som rättar stavning behöver normalt inte samma spårbarhet som ett system som rangordnar ärenden eller producerar beslutsunderlag.

Det är därför bättre att fråga:

Vad behöver vi kunna bevisa eller förstå i efterhand?

än att mekaniskt logga allt.

Loggar kan själva bli skyddsvärda informationsmängder

Loggning skapar samtidigt nya risker.

En detaljerad AI-logg kan innehålla:

- personuppgifter,
- sekretessbelagda uppgifter,
- promptar och svar,
- interna instruktioner,
- säkerhetsinformation,
- användarbeteenden,
- tekniska identifierare.

Loggar måste därför omfattas av samma tänkande kring:

- åtkomst,
- ändamål,
- lagringstid,
- sekretess,
- säkerhet,
- arkivering och gallring.

Gul signal: organisationen inför omfattande AI-loggning för spårbarhet men har inte bestämt vem som får läsa loggarna eller hur länge de ska finnas kvar.

Dokumentera det som faktiskt påverkar beslutet

I kapitel 4 behandlade vi AI som besluts- och handläggningsstöd. Där blir dokumentationsfrågan särskilt viktig.

Förvaltningslagen innehåller krav på dokumentation av uppgifter som kan ha betydelse för ett beslut och på motivering av beslut i de fall lagen kräver det.

Om AI påverkar handläggarens bedömning bör verksamheten därför kunna skilja mellan:

- AI:ns råa resultat,
- fakta eller underlag som förs in i ärendet,
- handläggarens egen bedömning,
- det slutliga beslutet och dess motivering.

Det är riskabelt att låta ett ogenomskinligt AI-resultat bli ett informellt mellanlager som påverkar beslut utan att dess betydelse går att se i efterhand.

Arkitekturprincip: Ju större påverkan AI har på en enskild eller på ett myndighetsbeslut, desto större anledning finns att skapa tydlig och verksamhetsmässigt begriplig spårbarhet.

Versionsinformation kan vara nödvändig

Generativ AI förändras över tid. Samma prompt kan ge olika svar efter ett modellbyte.

Om AI används i ett viktigt arbetsflöde kan därför information om modell och konfiguration bli relevant för reproducerbarhet och efterhandskontroll.

Det behöver inte betyda att myndigheten kan återskapa varje sannolikhetsberäkning i modellen. Men den kan behöva veta exempelvis:

- leverantör,
- tjänst,
- modellfamilj eller modellversion,
- datum,
- relevanta konfigurationsinställningar,
- version av systemprompt eller beslutad instruktion,
- vilken kunskapsbas som var ansluten.

Det är särskilt viktigt om lösningen förändras ofta.

RAG skapar flera dokumentationslager

En RAG-lösning illustrerar varför traditionellt dokumenttänkande inte alltid räcker.

Ett svar kan bygga på:

1. användarens fråga,
2. sökning i en kunskapsbas,
3. ett antal hämtade textstycken,
4. systeminstruktioner,
5. modellens generering,
6. eventuell mänsklig redigering.

För enklare kunskapsstöd kan det räcka att visa källhänvisningar för användaren.

För mer verksamhetskritisk användning kan det behövas större spårbarhet, exempelvis vilka källdokument eller versioner som låg bakom ett resultat.

Det betyder inte att varje embedding eller intern vektorsökning behöver arkiveras. Det betyder att man behöver identifiera **vilken informationsnivå som är relevant för myndighetens ansvar och efterhandskontroll**.

En arkitekt bör definiera informationslivscykeln

För varje viktig informationskategori i en AI-lösning bör arkitekturen kunna beskriva:

Informationskategori	Exempel	Fråga att besvara
Indata	prompt, fil, ärendeuppgifter	Varifrån kommer den och får den behandlas?
Kontext	RAG-träffar, systemprompt	Behöver vi veta vad modellen fick se?
Resultat	svar, klassificering, sammanfattning	Är resultatet arbetsmaterial eller del av verksamhetshandlingen?
Beslutsunderlag	rekommendation, poäng, urval	Hur dokumenteras påverkan på handläggningen?
Logg	användning, modell, tidpunkt	Vad behövs för spårbarhet och hur länge?
Metadata	modellversion, källor, användare	Behövs den för förståelse eller bevarande?
Arkivobjekt	färdig handling, beslutsunderlag	Hur förs det till ordinarie informationsförvaltning?

Tabellen behöver anpassas till varje lösning, men den tvingar fram rätt frågor tidigt.

Kontrollfrågor för offentlighet och spårbarhet

1. Informationsobjekten

- Vilka promptar, svar, filer, loggar och sammanställningar skapas?
- Vilka av dem har självständig betydelse för verksamheten?

2. Förvaring och åtkomst

- Var finns informationen?
- Är den tekniskt tillgänglig för myndigheten även om leverantören lagrar den?

3. Handlingens status

- Kan informationen vara inkommen eller upprättad?
- Finns arbetsmaterial som senare tillförs ett ärende?

4. Offentlighet och sekretess

- Kan allmänna handlingar identifieras och lämnas ut?
- Kan sekretesskyddad information avskiljas och prövas korrekt?

5. Dokumentation

- Går det att se vilket underlag som faktiskt påverkade en handläggning eller ett beslut?

6. Arkivering och gallring

- Vilka handlingar ska tas om hand för arkivering?
- Vilka får gallras och med vilket stöd?
- Styr retentionen av myndigheten eller av leverantören?

7. Spårbarhet

- Vad måste kunna förstås i efterhand?
- Behöver modellversion, källor eller systeminstruktion dokumenteras?

8. Exit

- Kan relevanta handlingar och metadata exporteras innan tjänsten avslutas?

Bedömning: grönt, gult eller rött

Grönt - normalt möjligt

Exempel:

- AI används för ett avgränsat stöd där slutprodukten tas om hand i myndighetens ordinarie dokumentprocess,
- informationskategorier och retention är definierade,
- relevanta handlingar kan exporteras och lämnas ut,
- ingen viktig verksamhetsinformation finns enbart i leverantörens historik,
- spårbarheten står i proportion till användningens betydelse.

Gult - utred först

Exempel:

- promptar och svar sparas i en extern tjänst,
- AI-resultat används i handläggning men kopplas inte tydligt till ärendet,
- RAG bygger på föränderliga källor utan versionshantering,
- myndigheten är osäker på vilka AI-genererade upptagningar som är allmänna handlingar,
- omfattande loggar skapas utan fastställd informationshantering.

Rött - gå inte vidare innan frågan är löst

Exempel:

- viktig beslutsinformation kan inte rekonstrueras eller dokumenteras,
- handlingar som måste bevaras försvinner enligt leverantörens retention,
- myndigheten kan inte söka fram eller exportera information som den kan behöva lämna ut,
- lösningen gör det praktiskt omöjligt att skilja allmänna handlingar från annan information eller att upprätthålla sekretesskyddet,

- verksamheten förlitar sig på AI-resultat som påverkar beslut men saknar begriplig spårbarhet.

Vanliga misstag

“Allt i AI-chatten är en allmän handling”

Inte nödvändigtvis. Vanliga kriterier i TF om handling, förvaring, inkommen och upprättad måste bedömas i den konkreta situationen.

“Inget i AI-chatten är en allmän handling”

Inte heller detta är en säker utgångspunkt. Elektronisk information kan omfattas av offentlighetsprincipen, även när den finns i externa tekniska miljöer.

“Leverantörens 30-dagars retention betyder att informationen får gallras efter 30 dagar”

Teknisk retention och rättsligt beslutad gallring är olika saker.

“Om vi loggar allt är vi spårbara”

En stor loggmängd utan tydligt ändamål, struktur och åtkomst kan skapa mer risk än nytta.

“Slutbeslutet räcker alltid”

Om AI tillför sakuppgifter eller får verklig betydelse för handläggningen kan även underlag och dokumentation bli viktiga för rättssäkerhet och efterhandskontroll.

Sammanfattning

AI skapar inte ett undantag från offentlighets- och arkivreglerna. Däremot skapar tekniken nya former av information och nya platser där information kan finnas.

De viktigaste principerna är:

- bedöm AI-information med de vanliga kriterierna för allmän handling,
- anta varken att alla promptar är allmänna handlingar eller att inga är det,
- kartlägg även information som finns i externa molntjänster,
- bygg lösningen så att allmänna handlingar kan identifieras och hanteras,
- skilj teknisk retention från rättsligt beslutad gallring,
- flytta bevarandevärd information till en kontrollerad informationsförvaltning,
- dimensionera spårbarheten efter AI-användningens konsekvenser,
- dokumentera särskilt tydligt när AI faktiskt påverkar handläggning eller beslut.

För arkitekten är kärnfrågan därför:

Kommer myndigheten fortfarande att kunna förstå, förvalta, hitta och vid behov lämna ut den information som AI-lösningen skapar och använder?

Om svaret är oklart behöver informationsarkitekturen lösas innan AI-lösningen blir verksamhetskritisk.

Viktigaste källorna

- Tryckfrihetsförordning (1949:105), särskilt 2 kap.: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/tryckfrihetsforordning-1949105_sfs-1949-105/
- Offentlighets- och sekretesslag (2009:400), särskilt 4 kap.: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/offentlighets-och-sekretesslag-2009400_sfs-2009-400/
- Arkivlag (1990:782): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/arkivlag-1990782_sfs-1990-782/
- Riksarkivets föreskrifter och allmänna råd RA-FS 2009:1 om elektroniska handlingar, konsoliderad med senare ändringar: <https://foreskrifter.riksarkivet.se/rafs/105>
- Förvaltningslag (2017:900), särskilt reglerna om dokumentation och motivering: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/forvaltningslag-2017900_sfs-2017-900/
- Dir. 2026:116 – En analys av tillämpningen av offentlighetsprincipen vid myndigheters användning av artificiell intelligens: <https://www.regeringen.se/rattsliga-dokument/kommittedirektiv/2026/09/dir.-2026116>

Kapitel 7

Från idé till arkitekturbeslut

Ett AI-initiativ börjar ofta med frågan *vilken modell ska vi använda?* För en myndighet bör arkitekturbeslutet börja tidigare i kedjan.

En bättre ordning är:

Vad ska AI:n göra, vilken information ska den använda, vem påverkas, vilken aktör får tillgång till informationen och vilka rättsliga eller säkerhetsmässiga gränser aktiveras?

Först därefter är det meningsfullt att låsa teknik, leverantör och arkitektur.

Det här kapitlet samlar bokens tidigare delar till en praktisk första kontroll för IT- och verksamhetsarkitekter. Syftet är inte att ersätta jurist, dataskyddsombud, säkerhetsspecialist, arkivfunktion eller upphandlingskompetens. Syftet är att hjälpa arkitekten att **identifiera rätt frågor tidigt**, innan ett tekniskt vägval har blivit dyrt att ändra.

Användningsfallet före produkten

Två verksamheter kan använda exakt samma AI-tjänst och ändå hamna i helt olika rättsliga situationer.

Att använda en språkmodell för att:

- förbättra språket i en redan offentlig text,
- sammanfatta interna mötesanteckningar,
- analysera ett socialförsäkringsärende,
- rangordna arbetssökande,
- prioritera objekt för kontroll,
- ge rekommendationer inför myndighetsbeslut,

är inte samma sak bara för att den tekniska modellen är densamma.

Det är därför **användningsfallet** som ska bedömas först.

En bra första beskrivning behöver inte vara lång. Den bör svara på fem frågor:

1. Vad ska AI-systemet göra?
2. Vilken information ska det använda?
3. Vem eller vad påverkas av resultatet?
4. Vem tillhandahåller och driver lösningen?
5. Vad händer med resultatet efter att AI:n har producerat det?

Om dessa frågor inte går att besvara är initiativet ännu inte moget för ett arkitekturbeslut.

Grönt, gult och rött är triage - inte juridiska besked

Bokens grönt-gult-rött-modell ska hjälpa till att prioritera arbetet.

Grönt - normalt möjligt

Grönt betyder att den första kontrollen inte visar någon tydlig särskild riskindikator.

Det kan exempelvis vara användning där:

- informationen är offentlig eller okänslig,
- inga personuppgifter behöver behandlas,
- AI:n inte påverkar enskildas rättigheter eller beslut,
- tjänsten är godkänd och informationshanteringen är känd,
- användningen ryms inom beslutad intern styrning,
- resultatet granskas på ett sätt som är rimligt för uppgiften.

Grönt betyder inte **regel-fritt**. Vanliga krav på säkerhet, kvalitet, upphandling, dokumentation och intern styrning gäller fortfarande.

Gult - bedöm innan ni går vidare

Gult betyder att en eller flera frågor behöver klarläggas innan arkitekturen låses eller lösningen tas i bruk.

Vanliga gula signaler är:

- personuppgifter,
- känsliga personuppgifter,
- sekretessbelagda uppgifter,
- extern AI-leverantör,
- tredjelandssätkomst,
- intern RAG över verksamhetsinformation,
- AI som påverkar prioritering eller bedömning av människor,
- osäker klassificering enligt AI-förordningen,
- oklart ansvar för promptar, loggar och AI-output,
- sektorsspecifik reglering som ännu inte analyserats.

Gult betyder inte att användningen är förbjuden. Det betyder att **en definierad fråga måste få ett svar**.

Rött - gå inte vidare innan begränsningen är löst

Rött betyder att det finns en tydlig blockerande fråga eller en risk för att användningen träffar ett förbud eller ett krav som måste hanteras före fortsatt design.

Exempel kan vara:

- en användning som kan omfattas av ett förbjudet AI-fall,
- behandling utan identifierat rättsligt stöd,

- sekretessbelagda uppgifter som ska lämnas till en aktör utan klarlagd rättslig grund för utlämnandet,
- säkerhetsskyddsklassificerade uppgifter i en lösning som inte är godkänd för dem,
- ett beslutssystem där obligatorisk mänsklig kontroll eller annan rättssäkerhetsmekanism saknas,
- arkivpliktig information som endast finns i en tjänst där den raderas enligt leverantörens egna standardvillkor.

Rött betyder inte nödvändigtvis **aldrig**. Det betyder **inte så här, inte ännu**.

AI-kontrollen i tio frågor

Följande tio frågor kan användas i tidig analys, arkitekturforum, initiativberedning eller inför upphandling.

De ska besvaras för det konkreta användningsfallet – inte för AI som teknik i allmänhet.

1. Vad ska AI:n faktiskt göra?

Beskriv funktionen med verksamhetsspråk.

Undvik formuleringar som:

“Vi ska införa generativ AI.”

Skriv hellre:

“Handläggare ska kunna få förslag på en sammanfattning av inkomna handlingar. Sammanfattningen ska granskas av handläggaren och får inte automatiskt tillföras beslutet.”

eller:

“Systemet ska rangordna kontrollobjekt utifrån uppgifter i myndighetens register och presentera en prioriteringslista för kontrollverksamheten.”

Ju mer konkret funktionen beskrivs, desto lättare blir det att avgöra vilka regler som aktiveras.

Grönt: avgränsat stöd med låg påverkan.

Gult: funktionen analyserar, klassificerar, rangordnar eller rekommenderar.

Rött: funktionen kan träffa förbjuden användning eller fatta/påverka beslut utan nödvändiga skyddsmekanismer.

2. Vilken information ska AI:n använda?

Lista informationskategorierna innan teknik väljs.

Fråga bland annat:

- Är informationen offentlig?
- Innehåller den personuppgifter?
- Innehåller den känsliga personuppgifter?
- Omfattas den av sekretess?
- Är den säkerhetsskyddsklassificerad eller del av säkerhetskänslig verksamhet?
- Finns verksamhetsspecifika begränsningar för hur den får användas?

En viktig princip är:

Klassificera informationen före tjänsten.

Om lösningen behöver fem olika informationsklasser kan det vara klokare att skapa flera tekniska zoner eller användningsmönster än att försöka få en enda AI-tjänst godkänd för allt.

Grönt: offentlig eller lågt skyddsvärd information som får användas för ändamålet.

Gult: personuppgifter, intern information eller sekretess som kräver analys.

Rött: information som lösningen eller leverantören inte får eller kan hantera.

3. Varför får just dessa uppgifter användas för detta ändamål?

Det räcker inte att myndigheten redan har tillgång till uppgifterna.

Frågan är om de får behandlas **för det nya AI-ändamålet**.

Detta är särskilt viktigt när AI används för:

- nya typer av analys,
- profilering,
- urval,
- återanvändning av stora datamängder,
- modellträning eller finjustering,
- kombination av register som tidigare hållits åtskilda.

Här kan GDPR, dataskyddslagen, brottsdatalagen eller sektorsspecifika registerförfattningar sätta ramarna.

Arkitektens uppgift: kunna beskriva informationsflöde och ändamål så tydligt att ansvarig juridisk funktion kan bedöma dem.

Gul signal: argumentet är enbart "vi har redan datan".

4. Vem påverkas av AI-resultatet?

Risken ökar när AI går från att hjälpa till med text till att påverka människor.

Fråga:

- Påverkas en enskilds rättighet, förmån eller skyldighet?
- Påverkar resultatet vem som granskas, prioriteras eller kontrolleras?
- Används resultatet i rekrytering eller personalledning?
- Skapas profiler, riskpoäng eller rangordningar?
- Kan ett felaktigt resultat få betydande konsekvenser?

En människa i processen gör inte automatiskt användningen lågrisk.

Om handläggaren i praktiken förväntas följa AI-rekommendationen kan AI:n ha stor faktisk påverkan även om en människa formellt fattar beslutet.

Grönt: AI:n påverkar främst form, språk eller intern produktivitet.

Gult: AI:n rekommenderar, prioriterar eller klassificerar människor eller ärenden.

Rött: AI:n fattar eller i praktiken styr betydande beslut utan tillräcklig rättslig och mänsklig kontroll.

5. Hur klassificeras användningen enligt AI-förordningen?

Kontrollera åtminstone:

- Är detta ett AI-system enligt förordningen?
- Är myndigheten deployer, provider eller båda?
- Kan användningen omfattas av ett förbud?
- Kan den vara högrisk?
- Finns transparenskrav?
- Finns krav på AI-kompetens, loggning, mänsklig kontroll eller annan styrning?

För högriskbedömningen måste **syfte och användningskontext** analyseras. Det räcker inte att känna till produktnamnet.

En generell AI-modell kan användas i både lågrisk- och högriskfall.

Gul signal: "leverantören säger att produkten inte är högrisk" används som enda klassificeringsunderlag.

Myndigheten behöver förstå sin egen användning och sitt eget ansvar.

6. Vem får tillgång till informationen - tekniskt och juridiskt?

Rita informationsflödet hela vägen.

Ta med:

- myndighetens användare,
- leverantören,
- underleverantörer,
- modellleverantör,
- driftleverantör,
- logg- och övervakningstjänster,
- supportfunktioner,
- eventuella mottagare utanför EU/EES.

Fråga sedan:

- Får uppgifterna lämnas till dessa aktörer?
- Vilka dataskyddsroller har de?
- Får leverantören använda uppgifterna för egna ändamål?
- Kan information användas för träning eller tjänsteutveckling?
- Var sker behandling och åtkomst?
- Vilka möjligheter finns att radera och exportera data?

Grönt: känt och kontrollerat informationsflöde med avtalad behandling.

Gult: komplex leverantörskedja eller tredjelandfrågor.

Rött: myndigheten kan inte förklara vilka aktörer som får åtkomst till skyddsvärd information.

7. Vilken mänsklig kontroll behövs?

“Human in the loop” är inte tillräckligt som kravformulering.

Beskriv i stället vad människan faktiskt ska kunna göra.

Exempel:

- förstå att resultatet är AI-genererat,
- bedöma dess rimlighet,
- se relevant underlag,
- upptäcka avvikande resultat,
- frångå rekommendationen,
- korrigera fel,
- stoppa processen,
- dokumentera varför AI-resultatet följdes eller inte följdes när det är relevant.

Mänsklig kontroll måste också vara realistisk.

Om systemet producerar tusentals rekommendationer per timme och en handläggare har några sekunder per rekommendation kan den formella kontrollen vara svag i praktiken.

Arkitekturfråga: Har användaren information, tid, kompetens och mandat att faktiskt kontrollera AI:n?

8. Vad måste kunna förstås och visas i efterhand?

En AI-lösning bör utformas för efterhandskontroll från början.

Fråga vad myndigheten behöver kunna svara på senare:

- Vilket system och vilken modellversion användes?
- Vilken instruktion eller konfiguration var aktiv?
- Vilken information låg till grund för resultatet?
- Vilket resultat producerades?
- Vem tog del av resultatet?
- Påverkade det ett beslut eller en annan åtgärd?
- Vilken mänsklig kontroll gjordes?
- När skedde detta?

Allt behöver inte loggas i alla lösningar. Men den nödvändiga spårbarheten måste definieras med utgångspunkt i verksamhet, rättsliga krav och risk.

Gul signal: organisationen upptäcker först efter driftsättning att det inte går att rekonstruera ett viktigt AI-stött beslut.

9. Finns sektorsspecifik reglering?

Detta är en av bokens viktigaste kontrollfrågor.

De generella reglerna är inte hela regelverket för en myndighet.

Kontrollera om användningsfallet berör exempelvis:

- särskilda registerförfattningar,
- brottsdatalogens område,
- tull-, skatte- eller polislagstiftning,
- hälso- och sjukvårdsregler,
- socialtjänstregler,
- utbildningsregler,
- verksamhetsspecifika sekretessbestämmelser,
- särskilda befogenhetslagar.

Specialregleringen kan exempelvis begränsa:

- ändamål,

- vilka uppgifter som får kombineras,
- sökningar och urval,
- åtkomst,
- utlämnande,
- behandlingstid,
- vilka åtgärder myndigheten får vidta.

AI skapar inte nya befogenheter.

Om myndigheten inte får använda uppgifterna eller fatta åtgärden utan AI, får tekniken normalt inte användas som genväg runt den begränsningen.

Bilaga B visar korta exempel från Tullverket, Polismyndigheten och Skatteverket.

10. Vem behöver godkänna eller medverka innan lösningen går vidare?

Den sista frågan är organisatorisk.

Identifiera vilka funktioner som faktiskt behöver vara med.

Beroende på användningsfallet kan det vara:

- verksamhetsansvarig,
- informationsägare,
- jurist,
- dataskyddsombud eller dataskyddsfunktion,
- informationssäkerhet,
- säkerhetsskydd,
- arkiv/informationsförvaltning,
- upphandling/inköp,
- HR,
- tillgänglighet eller kommunikation,
- systemägare och arkitekturforum.

Alla behöver inte delta i varje AI-initiativ.

Poängen är att **rätt kompetens ska kopplas in när en faktisk trigger finns.**

Det är bättre än två ytterligheter:

- att låta varje AI-idé gå genom en stor generell kommitté,
- eller att låta teknikteamet försöka göra alla bedömningar själva.

Sammanfatta kontrollen i ett beslutskort

Efter de tio frågorna bör initiativet kunna sammanfattas på en sida.

Ett enkelt beslutskort kan innehålla:

Område	Bedömning	Kort motivering	Åtgärd/ägare
Användningsfall	Grönt/Gult/Rött	Vad AI:n gör	Verksamhet
Information	Grönt/Gult/Rött	Informationsklasser	Informationsägare
Dataskydd	Grönt/Gult/Rött	Personuppgifter/ ändamål	Dataskydd/juridik
Sekretess/säkerhet	Grönt/Gult/Rött	Skyddsvärde och extern åtkomst	Säkerhet
AI-förordningen	Grönt/Gult/Rött	Roll/riskklass	Juridik/AI-styrning
Mänsklig påverkan	Grönt/Gult/Rött	Beslut, urval, profilering	Verksamhet/juridik
Leverantör	Grönt/Gult/Rött	Roller, plats, underleverantörer	Inköp/IT
Dokumentation	Grönt/Gult/Rött	Loggar, allmän handling, arkiv	Informationsförvaltning
Sektorsregler	Grönt/Gult/Rött	Identifierade specialregler	Juridik/verksamhet
Nästa beslut	-	Gå vidare / utred / stoppa	Beslutsägare

Det viktiga är inte färgen i sig utan att varje gul eller röd markering har:

1. en konkret fråga,
2. en ansvarig funktion,
3. ett villkor för när frågan anses löst.

Exempel: intern AI-assistent för ärendehandläggare

Anta att en myndighet vill införa en AI-assistent som kan söka i interna styrdokument och sammanfatta information åt handläggare.

Första beskrivningen låter relativt okomplicerad.

Steg 1 - funktion

AI:n ska söka i interna styrdokument och ge förslag på sammanfattningar.

Bedömning: grönt/gult.

Det är stöd, inte automatiserat beslut. Men nästa frågor avgör om risknivån stiger.

Steg 2 - information

RAG-indexet innehåller interna styrdokument, men vissa dokument kan innehålla personuppgifter och delar av materialet omfattas av sekretess.

Bedömning: gult.

Informationsmängden behöver avgränsas och klassificeras.

Steg 3 - ändamål

Materialet används för att stödja handläggning inom samma verksamhetsområde som dokumenten skapats för.

Det kan vara rimligt, men rättsligt stöd och eventuella sektorsregler behöver verifieras för personuppgifterna.

Bedömning: gult.

Steg 4 - påverkan på människor

AI:n rekommenderar inte beslut utan sammanfattar styrning. Handläggaren gör själv den materiella bedömningen.

Bedömning: grönt, förutsatt att användningsgränsen verkligen upprätthålls.

Steg 5 - AI-förordningen

Användningen behöver klassificeras, men inget i beskrivningen pekar direkt på ett förbjudet eller typiskt högriskfall.

Bedömning: grönt/gult tills klassificeringen dokumenterats.

Steg 6 - leverantör

Tjänsten är en extern SaaS-lösning och RAG-indexet lagras hos leverantören. Leverantörens underleverantörskedja är ännu inte analyserad.

Bedömning: gult.

Här behöver dataskydd, sekretess, lagringsplats, åtkomst och avtalsvillkor klarläggas.

Steg 7 - mänsklig kontroll

Svar visas som förslag med källhänvisning till de interna dokument som hämtats. Handläggaren ansvarar för att kontrollera originalkällan innan information används i ett ärende.

Bedömning: grönt, om användargränssnitt, utbildning och arbetssätt faktiskt stödjer detta.

Steg 8 - spårbarhet

Systemet loggar vilken källa som hämtats, men inte hela prompten eller svaret som standard.

Här måste myndigheten bestämma vilken dokumentation som behövs för användningen och hur betydelsefullt AI-material ska föras till ordinarie ärendehantering.

Bedömning: gult.

Steg 9 - sektorsregler

Verksamheten omfattas av en särskild registerförfattning.

Bedömning: gult tills det har verifierats att sökning, sammanställning och åtkomst rymms inom regleringen.

Steg 10 - ansvar

Juridik, dataskydd, informationssäkerhet och informationsförvaltning får var sin tydlig fråga. Arkitekturteamet fortsätter samtidigt med de delar som inte är blockerade.

Det samlade resultatet blir inte:

“AI är för riskabelt.”

Det blir:

“Användningsfallet ser möjligt ut, men fyra definierade frågor måste lösas innan produktionsarkitekturen godkänns.”

Det är precis vad den gula kategorin är till för.

Undvik kontrollmodellens vanligaste missbruk

En checklista kan skapa falsk trygghet om den används mekaniskt.

Misstag 1: grönt på nio frågor väger upp ett rött

Det gör det inte.

En enda blockerande fråga kan räcka för att stoppa den föreslagna lösningen.

Misstag 2: “ingen personuppgift” betyder låg risk

En AI-lösning kan vara problematisk utan personuppgifter, exempelvis på grund av:

- sekretess,
- säkerhetsskydd,
- upphovsrätt,
- offentlighet och arkiv,
- felaktig information till allmänheten,
- AI-förordningens krav.

GDPR är viktigt men är inte hela AI-styrningen.

Misstag 3: leverantörens compliance-rapport blir myndighetens bedömning

Leverantörens dokumentation är underlag.

Myndigheten måste fortfarande bedöma sin **egen användning**, sina uppgifter och sitt ansvar.

Misstag 4: mänsklig kontroll skrivs in som en mening i kravspecifikationen

Mänsklig kontroll behöver omsättas i:

- gränssnitt,
- behörighet,
- arbetssätt,
- utbildning,
- tid,
- dokumentation,
- möjlighet att frånga AI-resultatet.

Misstag 5: man granskar bara produktionslösningen

Risker uppstår även i:

- proof of concept,
- testdata,
- utvecklingsmiljö,
- manuella experiment,
- pilotprojekt,
- utvärdering hos leverantör.

“Det är bara en pilot” är inte ett undantag från sekretess, dataskydd eller säkerhetsskydd.

Arkitekturprinciper som följer av kontrollen

När kontrollmodellen används konsekvent leder den till några generella arkitekturprinciper.

Separera användningsfall med olika risk

En enda AI-plattform behöver inte automatiskt få tillgång till all information eller användas för alla typer av beslut.

Separata zoner, modeller eller tjänster kan göra styrningen enklare.

Minimera information innan den når AI:n

Skicka inte mer data än användningsfallet kräver.

Det kan innebära:

- filtrering,
- pseudonymisering,
- avgränsad RAG,

- borttagning av onödiga fält,
- rollbaserad åtkomst,
- separata index för olika informationsklasser.

Gör källor synliga när resultatet ska kontrolleras

För RAG och beslutsstöd är ett svar utan källspår ofta svårare att kontrollera än ett svar som visar vilket underlag det bygger på.

Bygg exit från början

Myndigheten bör kunna:

- exportera viktig information,
- byta leverantör,
- byta modell,
- flytta RAG-index,
- avsluta behandlingen,
- radera data hos leverantören enligt avtal och regler.

Lägg verksamhetskritisk dokumentation i myndighetens informationsmiljö

En extern AI-tjänst bör inte vara den enda platsen där viktiga beslutsunderlag eller arkivpliktig information finns.

Gör riskklassificeringen förändringsbar

Ett användningsfall kan byta riskprofil.

Exempel:

1. AI börjar som skrivstöd.
2. Den får tillgång till ärendedata.
3. Den börjar föreslå prioritering.
4. Rekommendationen kopplas till automatiserad handläggning.

Varje steg kan aktivera nya krav.

Därför behöver förändringshanteringen fråga:

Har ändringen förändrat ändamål, information, påverkan på människor, leverantörsflöde eller AI-förordningsklassificering?

När ska specialist kopplas in?

Det är ineffektivt att kräva full specialistgranskning av varje enkel AI-användning.

Men vissa triggers bör normalt leda till specialistbedömning.

Juridik

Koppla in juridik när exempelvis:

- rättsligt stöd eller befogenhet är oklart,
- sektorsspecifik reglering behöver tolkas,
- AI påverkar myndighetsutövning eller enskildas rättigheter,
- AI-förordningens klassificering är osäker,
- sekretessutlämnande behöver bedömas.

Dataskydd

Koppla in dataskyddskompetens när exempelvis:

- personuppgifter behandlas på nytt sätt,
- profilering eller omfattande analys förekommer,
- känsliga personuppgifter används,
- tredjelandsoverföring kan ske,
- konsekvensbedömning kan krävas.

Informations- och cybersäkerhet

Koppla in säkerhetskompetens när:

- skyddsvärd information lämnar befintlig säkerhetszon,
- extern AI eller nya underleverantörer införs,
- AI integreras med verksamhetskritiska system,
- nya attacktyper, prompt injection eller dataläckagerisker uppstår.

Säkerhetsskydd

Koppla in säkerhetsskyddsfunktion tidigt om användningen berör säkerhetskänslig verksamhet eller säkerhetsskyddsklassificerade uppgifter.

Arkiv och informationsförvaltning

Koppla in dessa funktioner när:

- AI skapar eller lagrar verksamhetsinformation,
- historik och loggar får betydelse,
- extern tjänst används som informationslager,
- bevarande, gallring eller utlämnande behöver lösas.

Ett bra resultat är ofta villkorat - inte binärt

Arkitekturbeslut behöver inte alltid vara "godkänd" eller "avslagen".

Ett mer användbart beslut kan vara:

Godkänd för pilot med offentlig information, utan personuppgifter och utan koppling till myndighetsbeslut. Produktionsinförande med ärendedata kräver separat dataskydds-, sekretess- och informationssäkerhetsbedömning.

eller:

Teknikvalet godkänns under förutsättning att leverantören stänger av användning av kunddata för modellträning, att EU/EES-behandling kan säkerställas och att export av loggar införs.

Den typen av villkor gör styrningen möjliggörande utan att bli otydlig.

Dokumentera också varför något bedömdes som grönt

Det är lätt att dokumentera problem och glömma de enkla fallen.

Men en kort motivering till varför ett användningsfall bedömts som låg risk har flera fördelar:

- samma fråga behöver inte utredas från början nästa gång,
- förändringar kan jämföras mot ursprungsbedömningen,
- verksamheten kan visa att en medveten bedömning gjorts,
- organisationen bygger upp återanvändbar erfarenhet.

Det behöver inte bli tung administration.

Ett par meningar kan räcka för ett enkelt användningsfall.

Från enskilda projekt till återanvändbara mönster

När flera AI-initiativ har bedömts bör myndigheten börja skapa **godkända användningsmönster**.

Exempel:

Mönster A - publikt skrivstöd

- endast offentlig eller icke skyddsvärd information,
- ingen ärendedata,
- mänsklig granskning före publicering,
- godkänd AI-tjänst,
- tydliga regler för vad som inte får matas in.

Detta kan ofta få en enkel grön väg.

Mönster B - intern RAG

- definierade informationskällor,

- åtkomst följer källsystemens behörigheter,
- källhänvisning visas,
- personuppgifts- och sekretessbedömning är gjord,
- index och loggar omfattas av informationsförvaltningen.

Detta kan bli ett återanvändbart gult-till-grönt mönster när skyddsåtgärderna är etablerade.

Mönster C - AI i beslut eller urval

- separat riskklassificering,
- juridisk bedömning,
- definierad mänsklig kontroll,
- dokumentation och loggning,
- bias- och kvalitetskontroller,
- uppföljning i drift.

Detta bör ha en tydligare och mer formaliserad väg.

När sådana mönster finns behöver varje nytt initiativ inte börja från noll.

Det är ett viktigt sätt att undvika att reglering blir liktydigt med långsamhet.

Kapitlets arbetsmodell

När en ny AI-idé kommer in, gör följande:

1. **Beskriv användningsfallet.**
2. **Klassificera informationen.**
3. **Identifiera ändamål och rättsligt stöd.**
4. **Bedöm påverkan på människor.**
5. **Klassificera enligt AI-förordningen.**
6. **Kartlägg leverantör och informationsflöde.**
7. **Definiera mänsklig kontroll.**
8. **Bestäm dokumentation och spårbarhet.**
9. **Kontrollera sektorsspecifik reglering.**
10. **Fördela gula och röda frågor till rätt ansvarig.**

Därefter finns normalt tre möjliga utfall:

Grönt: gå vidare inom beslutad styrning.

Gult: gå vidare med de delar som är möjliga, men lös definierade villkor före nästa beslutspunkt.

Rött: stoppa den aktuella utformningen tills den blockerande frågan är löst eller välj ett annat användningsmönster.

Det viktigaste att ta med sig

Arkitektens viktigaste bidrag är inte att kunna varje paragraf utantill.

Det är att kunna se **när arkitekturvalet aktiverar en rättslig eller organisatorisk fråga**.

En bra AI-arkitektur i en myndighet kan därför beskrivas som en lösning där:

- användningsfallet är tydligt,
- informationen används för rätt ändamål,
- rätt aktörer får tillgång till den,
- påverkan på människor är förstådd,
- AI-förordningens klassificering är gjord,
- mänsklig kontroll är verklig när den behövs,
- viktiga förlopp går att förstå i efterhand,
- sektorsregler har kontrollerats,
- och gula frågor har tydliga ägare.

Modellen ska göra det enklare att använda AI **där den är lämplig**, samtidigt som mer känsliga användningsfall identifieras innan de blivit tekniskt eller organisatoriskt inlåsta.

Viktigaste källorna

Det här kapitlet sammanför de rättskällor och officiella vägledningar som introducerats i tidigare kapitel. De viktigaste är:

- Europaparlamentets och rådets förordning (EU) 2024/1689, AI-förordningen, i aktuell konsoliderad lydelse.
- Europaparlamentets och rådets förordning (EU) 2016/679, GDPR.
- Förvaltningslag (2017:900).
- Tryckfrihetsförordning (1949:105) och offentlighets- och sekretesslag (2009:400).
- Säkerhetsskyddslag (2018:585) och säkerhetsskyddsförordning (2021:955).
- Arkivlag (1990:782).
- Digg och IMY:s riktlinjer för generativ AI inom offentlig förvaltning.
- EU-kommissionens AI Act Service Desk och AI Act Explorer.

Se bilaga A för samlad regelverkskarta och fullständiga källhänvisningar.

Kapitel 8

Praktiska scenarier

Huvudtexten avslutas med åtta typiska situationer där en myndighet kan vilja använda AI.

Scenarierna ger inte generella juridiska ja- eller nej-besked. Bedömningen beror bland annat på uppgifterna, påverkan på människor, leverantören och sektorsspecifik reglering.

Använd därför scenarierna som exempel på **hur man resonerar**, inte som facit för alla myndigheter.

Varje scenario använder samma struktur:

1. Vad vill verksamheten göra?
2. Vilka riskindikatorer finns?
3. Vilka regelverk blir särskilt relevanta?
4. Vilken preliminär färg får användningen?
5. Vad behöver arkitekten göra härnäst?

Scenario 1 - språkgranska en redan offentlig text

Situationen

En kommunikationsfunktion vill använda generativ AI för att förbättra språk, struktur och begriplighet i en text som redan är publicerad på myndighetens webbplats. Inga interna kommentarer, personuppgifter eller sekretessbelagda uppgifter ska skickas till tjänsten.

Riskindikatorer

Riskenivån är normalt låg. Den viktigaste frågan är om tjänsten är godkänd för användning och om den färdiga texten kvalitetssäkras innan publicering.

Relevanta regler

- AI-förordningens allmänna krav och eventuella transparensregler.
- Myndighetens interna AI-policy och informationssäkerhetsregler.
- Upphovsrätt kan behöva beaktas om större mängder externt skyddat material används som underlag.

Preliminär bedömning

Grönt, om underlaget verkligen är offentligt och okänsligt, tjänsten är godkänd och resultatet granskas av ansvarig medarbetare.

Arkitektens nästa steg

Kontrollera att användningsfallet omfattas av beslutad intern användning och att tjänstens villkor inte skapar oväntad återanvändning av data eller andra beroenden.

Detta är ett bra exempel på varför myndigheter inte bör behandla all AI som högrisk. Ett väl avgränsat användningsfall kan vara relativt okomplicerat.

Scenario 2 - sammanfatta offentliga dokument

Situationen

En myndighet vill låta en AI-tjänst sammanfatta offentliga rapporter, remisser och andra publikationer för internt analysstöd.

Riskindikatorer

Även om källdokumentet är offentliga kan AI:n göra fel, utelämna reservationer eller blanda ihop fakta. Om sammanfattningen senare används som beslutsunderlag ökar kraven på kvalitet och spårbarhet.

Relevanta regler

- AI-förordningen.
- Förvaltningslagens krav blir relevanta om sammanfattningen får betydelse i ärendehandläggning.
- Offentlighet och arkivering kan bli relevanta beroende på hur resultatet används och sparas.

Preliminär bedömning

Grönt för orientering och enklare internt kunskapsstöd.

Gult om sammanfattningen används som faktiskt underlag för beslut eller ersätter läsning av den auktoritativa källan.

Arkitektens nästa steg

Utforma lösningen så att användaren enkelt kan gå tillbaka till originalkällan. För viktiga arbetsflöden bör det vara tydligt vilka dokument sammanfattningen byggde på och att AI-output inte är en auktoritativ källa i sig.

Scenario 3 - sammanfatta ett ärende med personuppgifter

Situationen

Handläggare vill använda AI för att sammanfatta inkomna handlingar i ett ärende. Underlaget innehåller personuppgifter och kan även innehålla känsliga personuppgifter eller sekretessbelagd information.

Riskindikatorer

Här förändras situationen väsentligt. Frågan handlar inte längre bara om AI-resultatets kvalitet utan om **vilken information som lämnas till systemet, varför den får behandlas och vem som får åtkomst till den.**

Relevanta regler

- GDPR och dataskyddslagen.
- Eventuell sektorsspecifik registerförfattning.
- offentlighets- och sekretesslagen.
- säkerhetsskyddsregleringen om säkerhetskänslig verksamhet berörs.
- förvaltningslagen om sammanfattningen får betydelse för handläggning eller beslut.

Preliminär bedömning

Gult som utgångspunkt.

Det kan bli **rött** om uppgifter ska lämnas till en tjänst som inte får hantera dem, om rättsligt stöd eller ändamål saknas eller om säkerhetsskyddsklassificerad information förs till en otillåten miljö.

Arkitektens nästa steg

Dokumentera:

- informationskategorier,
- rättsligt ändamål,
- leverantörens och underleverantörers åtkomst,
- lagrings- och loggningsflöden,
- eventuell tredjelandsoverföring,
- hur output granskas mot originalhandlingarna.

Koppla in dataskydds- och juridisk kompetens samt säkerhetsfunktion efter behov innan teknikvalet låses.

Scenario 4 - intern RAG över myndighetens dokument

Situationen

Myndigheten vill bygga en intern AI-assistent som med RAG kan söka i styrdokument, handböcker, tidigare rapporter och andra interna kunskapskällor.

Riskindikatorer

”Intern” betyder inte automatiskt lågrisk. Kunskapsbasen kan innehålla personuppgifter, sekretess, inaktuella dokument eller information som olika användargrupper inte ska kunna se.

RAG skapar dessutom fler informationsobjekt än originaldokumentet: exempelvis textsegment, embeddings, index, cache och loggar.

Relevanta regler

- GDPR om personuppgifter förekommer.
- OSL och informationsklassning.
- arkiv- och informationshanteringsregler.
- säkerhetsskydd där det är relevant.
- AI-förordningen beroende på hur assistentens svar används.

Preliminär bedömning

Gult tills informationsmängder, behörighetsmodell och driftmiljö är klarlagda.

Det kan därefter bli relativt **grönt** för en avgränsad kunskapsassistent med okänsligt material och tydliga källhänvisningar.

Arkitektens nästa steg

Säkerställ bland annat:

- källstyrning och versionshantering,
- dokumentbehörigheter även i sök-/vektorskiktet,
- möjlighet att spåra svar till källor,
- hantering av borttagna och gallrade dokument,
- separation mellan informationsklasser om samma lösning inte bör hantera allt.

Scenario 5 - AI för riskurval och prioritering

Situationen

En myndighet vill använda AI för att rangordna objekt eller ärenden så att kontrollresurser läggs där sannolikheten för fel bedöms vara högst.

Riskindikatorer

Detta är ett tydligt exempel på att ett system kan påverka människor även om AI:n inte fattar det slutliga beslutet. Den som hamnar högt i ett riskurval kan bli föremål för kontroll, utredning eller annan myndighetsåtgärd.

Här blir sektorsspecifik reglering särskilt viktig. Det kan finnas uttryckliga regler om vilka uppgifter som får användas, för vilka analysändamål och hur urval får göras.

Relevanta regler

- AI-förordningens riskklassificering, beroende på verksamhetsområde och användning.
- GDPR eller brottsdatalogen beroende på behandlingens syfte.
- sektorsspecifika datalagar och verksamhetsförfattningar.

- regeringsformens och förvaltningslagens krav på legalitet, saklighet och proportionalitet där de är tillämpliga.
- diskrimineringsreglering och grundläggande rättigheter.

Preliminär bedömning

Gult, ofta mörkgult.

I vissa verksamheter kan användningen omfattas av AI-förordningens högriskregler eller andra särskilt strikta krav. Ett användningsfall får inte klassificeras som lågrisk bara för att en människa fattar det slutliga beslutet.

Arkitektens nästa steg

Beskriv hela kedjan från data till faktisk konsekvens:

- vilka egenskaper påverkar riskpoängen,
- vilka datakällor används,
- hur modeller testas för systematiska fel,
- hur en människa kan förstå och frånga resultatet,
- hur utfallet följs upp,
- vilken sektorslagstiftning som ger rättsligt stöd för analysen.

Scenario 6 - AI som handläggare

Situationen

AI:n läser ett ärende och föreslår vilken regel eller åtgärd som är relevant. Handläggaren fattar fortfarande beslutet.

Riskindikatorer

Den centrala frågan är hur stor **faktisk påverkan** AI-rekommendationen får.

Om systemet bara hjälper användaren att hitta relevanta dokument är risken lägre. Om systemet däremot föreslår rättslig bedömning, utfall eller beslut och handläggare normalt förväntas följa rekommendationen är påverkan betydligt större.

Relevanta regler

- förvaltningslagen.
- GDPR, inklusive artikel 22 när förutsättningarna för den bestämmelsen är uppfyllda.
- AI-förordningen, inklusive möjliga högriskregler och krav på mänsklig kontroll.
- sektorsspecifik reglering.
- diskrimineringsregler och grundläggande rättigheter.

Förvaltningslagen medger att myndighetsbeslut kan fattas automatiserat, men det innebär inte att varje AI-baserad beslutsarkitektur automatiskt är tillåten. Övrig tillämplig rätt måste fortfarande uppfyllas.

Preliminär bedömning

Gult som normal utgångspunkt när AI:n materiellt påverkar bedömningen.

Det kan närma sig **grönt** om systemet endast erbjuder begränsad informationssökning som är enkel att verifiera.

Det kan bli **rött** om obligatoriska skyddsåtgärder saknas, rättsligt stöd inte är klarlagt eller användningen träffar ett förbud.

Arkitektens nästa steg

Testa om den mänskliga kontrollen är verklig:

- Förstår handläggaren varför förslaget gavs?
- Finns tillgång till originalunderlaget?
- Kan förslaget enkelt frångås?
- Finns tid och organisatoriska förutsättningar att faktiskt granska det?
- Loggas AI-resultat och handläggarens beslut på ett ändamålsenligt sätt?

För vissa högrisk-AI-system som används av offentliga organ kommer AI-förordningen dessutom att kräva en konsekvensbedömning av påverkan på grundläggande rättigheter innan systemet tas i bruk när de berörda högriskreglerna blir tillämpliga. För Annex III-fallen är tillämpningsdatumet den 2 december 2027.

Scenario 7 - AI-chatbot för allmänheten

Situationen

Myndigheten vill erbjuda en chatbot på webbplatsen som svarar på frågor om regler, tjänster och myndighetens verksamhet.

Riskindikatorer

Riskenivån beror starkt på vad chatboten får göra.

En chatbot som hänvisar till publicerad information är något annat än en chatbot som:

- tar emot uppgifter om enskilda,
- ger individanpassade rättsliga besked,
- hjälper till att lämna in ärenden,
- bedömer rätt till en förmån,
- skapar myndighetens faktiska svar i ett enskilt ärende.

Dessutom finns en grundläggande risk att användaren uppfattar ett sannolikt men felaktigt AI-svar som myndighetens auktoritativa besked.

Relevanta regler

- AI-förordningens transparenskrav för system som interagerar med människor.

- GDPR om användaren lämnar personuppgifter.
- förvaltningsrättsliga regler om service och handläggning beroende på funktion.
- lagen (2018:1937) om tillgänglighet till digital offentlig service när chatboten ingår i en digital tjänst som omfattas av lagen.
- offentlighet, dokumentation och arkivering beroende på om kommunikationen blir del av ett ärende.

Preliminär bedömning

Grönt till gult för en tydligt avgränsad informationschatbot över publicerat material.

Gult eller högre om chatboten hanterar individuppgifter eller ger svar som får betydelse i konkreta ärenden.

Arkitektens nästa steg

Utforma gränserna uttryckligt:

- vad chatboten får svara på,
- när den ska hänvisa till mänsklig handläggare,
- hur den visar källor,
- hur användaren informeras om att det är AI,
- vilka personuppgifter som får lämnas,
- hur konversationer sparas eller raderas.

Scenario 8 – AI automatiserar delar av ett myndighetsbeslut

Situationen

Myndigheten vill automatisera ett ärendeflöde där AI analyserar underlaget och producerar ett resultat som direkt leder till beslut för en fysisk person, eller där mänsklig medverkan är mycket begränsad.

Riskindikatorer

Det här är ett av bokens tydligaste högriskområden.

Frågorna omfattar bland annat:

- om automatiserat beslutsfattande är tillåtet i den aktuella verksamheten,
- om GDPR artikel 22 är tillämplig,
- om användningen klassificeras som högrisk enligt AI-förordningen,
- om sektorsspecifika regler begränsar behandlingen,
- hur beslutet kan motiveras och förklaras,
- hur fel upptäcks och rättas,
- vilka möjligheter den enskilde har att få beslutet omprövat eller granskat.

AI-förordningens Annex III pekar uttryckligen ut flera användningar som högrisk, bland annat AI som används av offentliga myndigheter för att bedöma fysiska personers rätt till vissa väsentliga offentliga tjänster och förmåner. Dessa Annex III-regler börjar tillämpas den 2 december 2027. För offentliga organ kommer vissa sådana högriskanvändningar dessutom att kräva en bedömning av påverkan på grundläggande rättigheter före användning.

Relevanta regler

- förvaltningslagen och eventuell specialförfattning.
- GDPR och dataskyddslagen.
- AI-förordningen, inklusive Annex III samt krav på mänsklig kontroll och konsekvensbedömning av grundläggande rättigheter där de är tillämpliga.
- diskrimineringsreglering och grundläggande rättigheter.
- dokumentations-, offentlighets- och arkivregler.

Preliminär bedömning

Rött tills den rättsliga och verksamhetsmässiga ramen är klarlagd.

Rött betyder inte att automatiserade myndighetsbeslut generellt är förbjudna. Förvaltningslagen anger uttryckligen att beslut kan fattas automatiserat. Färgen betyder i stället att ett sådant AI-användningsfall inte bör gå vidare som en vanlig teknisk implementation innan rättsligt stöd, riskklassificering, skyddsåtgärder, dokumentation och ansvar är utredda.

Arkitektens nästa steg

Detta användningsfall bör ha ett formaliserat tvärfunktionellt beslut före implementation. Arkitekturbeskrivningen behöver åtminstone visa:

- rättsligt stöd och ändamål,
- AI-systemets roll i beslutet,
- datakällor och kvalitetskontroller,
- hur diskriminerings- och felrisker testas,
- mänsklig kontroll när sådan krävs,
- motivering och förklarbarhet,
- loggning och spårbarhet,
- incident- och rättelseprocess,
- ansvarig systemägare och verksamhetsägare.

Vad scenarierna visar

De åtta scenarierna ger tre återkommande slutsatser.

1. Produkten avgör inte risknivån

Samma generativa AI-tjänst kan vara relativt okomplicerad i ett användningsfall och olämplig i ett annat.

Bedöm därför:

användning + information + påverkan + aktör + rättslig kontext

inte bara produktnamnet.

2. Gult är en normal färg i reglerad verksamhet

Många värdefulla AI-användningar kommer att börja som gula därför att de innehåller personuppgifter, intern information eller påverkar en verksamhetsprocess.

Det betyder inte att de ska stoppas.

Det betyder att nästa fråga ska vara konkret:

Vad behöver vi få klarlagt för att kunna gå vidare?

En mogen myndighet bör därför inte mäta framgång i hur många initiativ som klassificeras gröna. Den bör mäta sin förmåga att snabbt och korrekt lösa de gula frågorna.

3. Rött betyder ofta “inte så här”

Ett rött resultat kan ibland lösas genom att ändra arkitekturen.

Exempel:

- använd en annan driftmiljö,
- ta bort en informationskategori,
- inför verklig mänsklig kontroll,
- begränsa AI:n till informationssökning i stället för bedömning,
- separera verksamheter med olika rättsliga förutsättningar,
- ändra avtalsvillkor eller leverantör,
- bygg den nödvändiga dokumentationen och riskhanteringen innan användning.

Det är här arkitekturkompetensen blir särskilt värdefull. Regler behöver inte bara skapa stoppunkter; de kan omsättas till **designkrav**.

En sista kontroll före nästa steg

När ett AI-initiativ har analyserats bör arkitekten kunna sammanfatta det på en sida:

Fråga	Kort svar
Vad gör AI:n?	Avgränsad funktion och syfte
Vilka uppgifter används?	Informationskategorier och skyddsvärde

Fråga	Kort svar
Vem påverkas?	Personer, ärenden eller endast intern produktion
Vem får åtkomst?	Myndighet, leverantör, underleverantör och land/region
Vilka regler är centrala?	Generella och sektorsspecifika
Hur klassificeras AI-användningen?	Förbjuden, högrisk, transparenskrav eller annan användning
Hur sker mänsklig kontroll?	Konkret arbetsmoment, inte bara rollnamn
Vad dokumenteras?	Underlag, output, modell/version, beslut och loggar efter behov
Vilka frågor är fortfarande gula?	Namngivna öppna bedömningar
Vem äger beslutet att gå vidare?	Tydlig verksamhets- och systemägare

Om detta går att beskriva tydligt är initiativet betydligt lättare att granska, upphandla, bygga och förvalta.

Viktigaste källorna

- Förvaltningslag (2017:900), särskilt 5, 27, 28 och 32 §§: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/forvaltningslag-2017900_sfs-2017-900/
- Förordning (EU) 2016/679 (GDPR), särskilt artikel 22: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- AI-förordningen – AI Act Explorer: <https://ai-act-service-desk.ec.europa.eu/en/ai-act-explorer>
- AI-förordningen – Annex III: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3>
- AI-förordningen – artikel 27 om konsekvensbedömning av grundläggande rättigheter: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-27>
- Digg/IMY – Riktlinjer för generativ AI inom offentlig förvaltning: <https://www.digg.se/ai-for-offentlig-forvaltning/riktlinjer-for-generativ-ai>
- Offentlighets- och sekretesslag (2009:400): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/offentlighets-och-sekretesslag-2009400_sfs-2009-400/
- Arkivlag (1990:782): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/arkivlag-1990782_sfs-1990-782/

Bilaga A. Regelverkskarta och källor

Den här bilagan är en orienteringskarta. Den visar vilka generella rätts- och styrkällor som oftast behöver kontrolleras när en svensk myndighet planerar eller använder AI.

Kartan är **inte en uttömmande rättsutredning**. Vilka regler som faktiskt gäller avgörs av det konkreta användningsfallet, myndighetens uppdrag, vilka uppgifter som behandlas och vilken sektorsspecifik reglering som finns.

Källorna nedan är verifierade per **7 september 2026**.

A.1 Bindande rätt

Källa	Vad den främst reglerar	När den blir särskilt viktig för AI
EU:s AI-förordning, förordning (EU) 2024/1689, i gällande lydelse	AI-specifika krav, förbjudna användningar, högrisk-AI, transparens, roller och skyldigheter	Vid all klassificering av ett AI-användningsfall; särskilt när AI påverkar människor, beslut eller grundläggande rättigheter
EU:s dataskyddsförordning (GDPR), förordning (EU) 2016/679	Behandling av personuppgifter	När personuppgifter förekommer i promptar, träningsdata, RAG, loggar, output eller andra delar av lösningen
Lag (2018:218) med kompletterande bestämmelser till EU:s dataskyddsförordning	Svenska kompletteringar till GDPR	Tillsammans med GDPR vid personuppgiftsbehandling i svensk verksamhet
Regeringsformen (1974:152)	Grundläggande krav på offentlig makt, legalitet, saklighet, likabehandling och skydd för individen	När AI påverkar myndighetsutövning, urval, prioritering eller behandling av människor
Förvaltningslag (2017:900)	Handläggning, service, legalitet, objektivitet, proportionalitet, dokumentation, motivering och beslut	När AI används i ärendehandläggning eller som stöd för bedömning och beslut
Tryckfrihetsförordningen (1949:105), särskilt 2 kap.	Allmänna handlingars offentlighet	När promptar, svar, loggar, RAG-material eller annan AI-relaterad information kan bli allmän handling
Offentlighets- och sekretesslag (2009:400)	Sekretess och hantering av skyddade uppgifter	Innan sekretessreglerade uppgifter lämnas till en AI-tjänst, leverantör eller annan aktör
Arkivlag (1990:782)	Myndigheters arkiv, bevarande, ordnande och gallring	När AI skapar eller bearbetar information som behöver bevaras, spåras eller gallras korrekt

Källa	Vad den främst reglerar	När den blir särskilt viktig för AI
Säkerhetsskyddslag (2018:585) och säkerhetsskyddsförordning (2021:955)	Skydd av säkerhetskänslig verksamhet och säkerhetsskyddsklassificerade uppgifter	När AI-lösningen, leverantören, driftsmiljön eller informationsmängden berör Sveriges säkerhet
Lag (2016:1145) om offentlig upphandling	Upphandling och anskaffning	När AI-tjänster, modeller, plattformar eller konsultstöd anskaffas externt
Diskrimineringslag (2008:567)	Förbud mot diskriminering och krav på lika rättigheter och möjligheter	När AI gör urval, rangordnar, rekommenderar eller påverkar bedömningar av personer
Brottsdatalog (2018:1177)	Personuppgiftsbehandling för brottsbekämpande ändamål	För behöriga myndigheter när AI används för att förebygga, upptäcka, utreda eller lagföra brott
Lag (1960:729) om upphovsrätt till litterära och konstnärliga verk	Upphovsrätt, inskränkningar och bland annat text- och datautvinning	När AI använder skyddat material i RAG, analys, träning eller finjustering eller när AI-genererat material publiceras
Lag (2018:1937) om tillgänglighet till digital offentlig service	Tillgänglighet i offentlig digital service	När AI byggs in i webbplatser, appar eller andra digitala tjänster för allmänheten
Cybersäkerhetslag (2025:1506)	Riskhantering, säkerhetsåtgärder och incidenthantering för verksamhetsutövare inom lagens tillämpningsområde	När en myndighet eller verksamhet omfattas av lagen och AI blir en del av dess informationssystem, tjänster eller leverantörskedja

A.2 Officiell vägledning och nationell inriktning

Dessa källor är inte likställda med lag eller förordning, men de är viktiga för att förstå hur reglerna kan omsättas i offentlig verksamhet.

Källa	Typ	Betydelse för arkitekten
Digg/IMY - Riktlinjer för generativ AI inom offentlig förvaltning	Officiell myndighetsvägledning	Praktiskt stöd om bland annat ledning, dataskydd, sekretess, informationssäkerhet, anskaffning, upphovsrätt och mänsklig kontroll
EU-kommissionens AI Act Service Desk och AI Act Explorer	Officiellt EU-stöd	Praktiskt stöd för att läsa AI-förordningen, klassificera användningar och hitta artiklar, bilagor och vägledningar
Sveriges AI-strategi (2026)	Regeringsstrategi	Visar nationell inriktning mot ökad och ansvarsfull AI-användning

Källa	Typ	Betydelse för arkitekten
Sveriges digitaliseringsstrategi 2025-2030	Regeringsstrategi	Placerar AI, data och säkerhet i ett bredare perspektiv för offentlig förvaltning
En molnpolicy för Sverige (2026)	Regeringspolicy	Relevant vid val av moln- och AI-tjänster, särskilt för kontroll över data, beroenden och digital suveränitet
IMY:s vägledningar om GDPR, DPIA och tredjelandsoverföring	Tillsynsmyndighetsvägledning	Hjälper till att bedöma personuppgiftsroller, risker och överföringar utanför EU/EES
Riksarkivets föreskrifter om elektroniska handlingar	Föreskrifter och allmänna råd	Viktiga för bevarande, dokumentation och hantering av elektronisk information

A.3 Sektorsspecifik reglering

Den generella regelverkskartan räcker inte alltid. Många myndigheter har särskilda lagar om exempelvis:

- vilka personuppgifter som får behandlas,
- vilka ändamål behandlingen får ha,
- sökning och urval,
- vilka uppgifter som får göras gemensamt tillgängliga,
- utlämnande och åtkomst,
- längsta behandlingstid,
- särskilda befogenheter eller verksamhetsförutsättningar.

Det innebär att en lösning kan vara tekniskt identisk i två myndigheter men ändå få olika rättslig bedömning.

Arkitektens kontrollfråga:

Finns det registerförfattning, verksamhetslag eller annan specialreglering som begränsar vilka uppgifter vi får använda, för vilket ändamål och på vilket sätt?

Bilaga B visar tre konkreta exempel.

A.4 Primärkällor

EU

- AI-förordningen: <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng>
- AI Act Explorer: <https://ai-act-service-desk.ec.europa.eu/en/ai-act-explorer>
- GDPR: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>

Svensk rätt

- Regeringsformen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/kungorelse-1974152-om-beslutad-ny-regeringsform_sfs-1974-152/
- Förvaltningslagen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/forvaltningslag-2017900_sfs-2017-900/
- Tryckfrihetsförordningen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/tryckfrihetsforordning-1949105_sfs-1949-105/
- Offentlighets- och sekretesslagen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/offentlighets-och-sekretesslag-2009400_sfs-2009-400/
- Arkivlagen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/arkivlag-1990782_sfs-1990-782/
- Dataskyddslagen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-2018218-med-kompletterande-bestammelser_sfs-2018-218/
- Säkerhetsskyddslagen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/sakerhetsskyddslag-2018585_sfs-2018-585/
- Säkerhetsskyddsförordningen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/sakerhetsskyddsforordning-2021955_sfs-2021-955/
- LOU: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-20161145-om-offentlig-upphandling_sfs-2016-1145/
- Diskrimineringslagen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/diskrimineringslag-2008567_sfs-2008-567/
- Brottssdatalagen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/brottsdatalag-20181177_sfs-2018-1177/
- Upphovsrättslagen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-1960729-om-upphovsratt-till-litterara-och_sfs-1960-729/
- Lagen om tillgänglighet till digital offentlig service: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-20181937-om-tillganglighet-till-digital_sfs-2018-1937/
- Cybersäkerhetslagen: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/cybersakerhetslag-20251506_sfs-2025-1506/

Officiell vägledning och strategi

- Digg/IMY – AI för offentlig förvaltning: <https://www.digg.se/ai>
- Digg/IMY – Riktlinjer för generativ AI: <https://www.digg.se/ai-for-offentlig-forvaltning/riktlinjer-for-generativ-ai>
- Sveriges AI-strategi: <https://www.regeringen.se/informationsmaterial/2026/02/sveriges-ai-strategi/>
- Sveriges digitaliseringsstrategi 2025–2030: <https://www.regeringen.se/regeringens-politik/digitaliseringsstrategin-2025-2030/>

- En molnpolicy för Sverige: <https://www.regeringen.se/informationsmaterial/2026/05/en-molnpolicy-for-sverige-for-okad-sakerhet-effektivitet-och-innovation-i-den-offentliga-forvaltningen/>

A.5 Läs källorna i rätt ordning

När två källor verkar säga olika saker bör man inte väga dem som likvärdiga. En praktisk ordning är:

1. **bindande EU-rätt, grundlag, lag och förordning,**
2. **myndighetsföreskrifter inom rätt område,**
3. **officiell vägledning och praxis,**
4. **strategier och policyer,**
5. **intern styrning.**

Intern policy kan ställa högre interna krav på användning av en viss AI-tjänst, men kan inte göra en rättsligt förbjuden behandling tillåten. På motsvarande sätt innebär en positiv nationell AI-strategi inte att de bindande reglerna sätts åt sidan.

Bilaga B. Exempel på sektorsspecifik reglering

Den här bilagan visar varför den generella AI-regleringen inte alltid räcker. Tullverket, Polismyndigheten och Skatteverket används som exempel eftersom de har tydliga specialregler om personuppgiftsbehandling och analys.

Bilagan är **inte uttömmande** och ersätter inte en rättslig analys av ett konkret användningsfall. Källorna är verifierade per **7 september 2026**.

B.1 Tullverket

Viktiga specialregler

Tulldatalag (2026:127) gäller behandling av personuppgifter i Tullverkets bland annat fiskala och kontrollrelaterade verksamhet. Lagen omfattar uttryckligen övervakning, revision och annan kontroll eller analys.

Lag (2018:1694) om Tullverkets behandling av personuppgifter inom brottsdatalagens område gäller tillsammans med brottsdatalagen när Tullverket behandlar personuppgifter för att förebygga, förhindra eller upptäcka brottslig verksamhet, utreda eller lagföra brott eller verkställa uppbörd. Lagen pekar dessutom vidare på flera andra specialförfattningar, bland annat om PNR, internationellt polisiärt samarbete och tullbefogenheter.

Vad betyder det för AI?

För en AI-lösning räcker det därför inte att konstatera att GDPR eller brottsdatalagen i princip tillåter behandling. Arkitekten behöver kontrollera **vilken verksamhetsgren användningen tillhör och vilket ändamål den konkreta analysen har**.

Ett AI-baserat riskurval i tullkontroll kan exempelvis behöva bedömas mot:

- tillåtna ändamål för behandling,
- vilka uppgifter som får användas,
- åtkomst och elektroniskt utlämnande,
- behandlingstid,
- särskilda regler för brottsbekämpande verksamhet,
- regler om vilka befogenheter som faktiskt finns efter att ett urval gjorts.

Praktisk arkitektfråga:

Använder vi AI för vanlig tull-/kontrollverksamhet eller för brottsbekämpning, och vilken specialreglering gäller för just den behandlingen?

Primärkällor

- Tulldatalag (2026:127): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/tulldatalag-2026127_sfs-2026-127/
- Lag (2018:1694) om Tullverkets behandling av personuppgifter inom brottsdatalagens område: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-20181694-om-tullverkets-behandling-av_sfs-2018-1694/
- Brottsdatalag (2018:1177): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/brottsdatalag-20181177_sfs-2018-1177/

B.2 Polismyndigheten

Viktiga specialregler

Brottsdatalag (2018:1177) ger den generella ramen för personuppgiftsbehandling av behöriga myndigheter för brottsbekämpande ändamål.

Lag (2018:1693) om polisens behandling av personuppgifter inom brottsdatalagens område kompletterar denna med särskilda regler för Polismyndigheten. Den reglerar bland annat grundläggande behandling, gemensamt tillgängliga uppgifter, behandlingstider, register och forensiska ändamål.

Vad betyder det för AI?

AI för exempelvis underrättelseanalys, matchning, prioritering eller riskbedömning måste därför utformas med hänsyn till mer än modellens träffsäkerhet.

Arkitekten behöver bland annat förstå:

- för vilket brottsbekämpande ändamål uppgifterna används,
- vilka uppgifter som får göras gemensamt tillgängliga,
- vilka sökningar och sammanställningar som är tillåtna,
- hur länge uppgifterna får behandlas,
- vem som får komma åt information och AI-resultat,
- hur felaktiga eller missvisande AI-indikationer kan påverka enskilda.

AI-förordningens klassificering måste samtidigt göras separat. Vissa AI-användningar inom brottsbekämpning finns bland de områden som kan vara högrisk enligt AI-förordningen.

Praktisk arkitektfråga:

Vilken faktisk åtgärd eller bedömning kan AI-resultatet leda till, och är både databehandlingen och den efterföljande användningen rättsligt tillåtna?

Primärkällor

- Lag (2018:1693) om polisens behandling av personuppgifter inom brottsdatalagens område: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-20181693-om-polisens-behandling-av_sfs-2018-1693/

- Brottssdatalag (2018:1177): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/brottsdatalag-20181177_sfs-2018-1177/
- AI-förordningen, bilaga III: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3>

B.3 Skatteverket

Viktiga specialregler

Beskattningsdatalag (2026:125) gäller personuppgiftsbehandling i Skatteverkets beskattningsverksamhet. Den nya lagen trädde i kraft den 2 april 2026 och ersatte den tidigare lagen från 2001.

Folkbokföringsdatalag (2026:126) gäller personuppgiftsbehandling i folkbokföringsverksamheten. Den omfattar bland annat samordnad behandling, kontroll och analys av identifierings- och folkbokföringsuppgifter.

Lag (2018:1696) om Skatteverkets behandling av personuppgifter inom brottssdatalagens område gäller den brottsbekämpande verksamheten och innehåller särskilda regler, bland annat om sökning.

Vad betyder det för AI?

Samma myndighet kan alltså behöva använda olika rättsliga ramar beroende på om AI-lösningen används för exempelvis:

- beskattning och skattekontroll,
- folkbokföring och identitetskontroll,
- brottsbekämpning.

Det är särskilt relevant för AI-baserad analys och urval. Att en datamängd finns hos Skatteverket innebär inte i sig att den får användas fritt i varje modell eller för varje nytt analysändamål.

Arkitekten behöver kontrollera:

- vilket lagreglerat ändamål AI-analysen stöder,
- vilka datakällor som får kombineras,
- regler för sökning, urval och åtkomst,
- behandlingstid,
- om användningen har gått från administrativ kontroll till brottsbekämpande ändamål.

Praktisk arkitektfråga:

Vilken av Skatteverkets rättsliga verksamhetsdomäner befinner sig AI-användningen i, och förändras rättsläget om syftet eller användningen av resultatet ändras?

Primärkällor

- Beskattningsdatalag (2026:125): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/beskattningsdatalag-2026125_sfs-2026-125/
- Folkbokföringsdatalag (2026:126): https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/folkbokforingsdatalag-2026126_sfs-2026-126/
- Lag (2018:1696) om Skatteverkets behandling av personuppgifter inom brottsdatalagens område: https://www.riksdagen.se/sv/dokument-och-lagar/dokument/svensk-forfattningssamling/lag-20181696-om-skatteverkets-behandling-av_sfs-2018-1696/

B.4 Den gemensamma lärdomen

De tre exemplen visar samma grundprincip:

AI ger inte en myndighet en ny rätt att behandla information, göra urval eller vidta åtgärder som myndigheten annars saknar rättsligt stöd för.

Sektorsreglering avgör ofta inte om *AI som teknik* får användas. Den avgör i stället sådant som är minst lika viktigt för arkitekturen:

- vilka uppgifter som får behandlas,
- för vilka ändamål,
- vilka uppgifter som får kombineras,
- hur sökning och urval får ske,
- vem som får ha åtkomst,
- hur länge information får behandlas,
- vilka åtgärder myndigheten får vidta utifrån resultatet.

Det är därför den sektorsspecifika kontrollen bör göras **innan datamodell, integrationer och leverantörsval låses**.